

BAN CƠ YẾU CHÍNH PHỦ
HỌC VIỆN KỸ THUẬT MẬT MÃ



CHUYÊN ĐỀ
**NGHIÊN CỨU XÂY DỰNG HỆ THỐNG TỰ ĐỘNG
PHẢN ỨNG SỰ CỐ DỰA TRÊN SOAR MÃ NGUỒN MỞ**

Ngành: An toàn thông tin

Sinh viên thực hiện:

Nguyễn Đức Chiến – MSSV: AT190107

Người hướng dẫn:

ThS. Hoàng Thanh Nam

Khoa An toàn thông tin – Học viện Kỹ thuật mật mã

Hà Nội, 2025

MỤC LỤC

MỤC LỤC.....	2
DANH MỤC HÌNH ẢNH.....	4
DANH MỤC BẢNG.....	4
LỜI CẢM ƠN.....	5
LỜI MỞ ĐẦU.....	5
CHƯƠNG 1 : CƠ SỞ LÝ THUYẾT	7
1.1. Giám sát an toàn mạng thông tin trong mạng máy tính.....	7
1.1.1. Tình hình an toàn thông tin trong mạng máy tính hiện nay	7
1.1.2. Các mối đe dọa và lỗ hổng phổ biến.....	7
1.1.3. Nhu cầu giám sát và ứng phó sự cố bảo mật.....	8
1.2. Tổng quan về Security Information and Event Management (SIEM) .	9
1.2.1. Khái niệm về SIEM.....	9
1.2.2. Cách thức hoạt động của SIEM.....	9
1.2.3. Một số giải pháp SIEM nổi bật.....	11
1.3. Tổng quan về Security Orchestration, Automation and Response(SOAR)	14
1.3.1. Khái niệm về SOAR.....	14
1.3.2. Thành phần và chức năng chính của một hệ thống SOAR.....	14
1.3.3. Cách thức hoạt động.....	15
CHƯƠNG 2 : XÂY DỰNG GIẢI PHÁP HỆ THỐNG SOAR	17
2.1. Giới thiệu về Wazuh	17
2.1.1. Tổng quan về Wazuh	17
2.1.2. Kiến trúc của Wazuh.....	18

2.1.3. Các thành phần và chức năng của Wazuh.....	20
2.1.4. Một số port phổ biến.....	26
2.2. Shuffle SOAR.....	27
2.2.1. Kiến trúc của Shuffle.....	27
2.2.2. Các framework Shuffle sử dụng.....	28
2.2.3. Chức năng chính của Shuffle.....	29
2.2.4. Cơ chế hoạt động của workflow.....	29
2.3. VirusTotal.....	31
2.4. Telegram.....	32
CHƯƠNG 3 : TRIỂN KHAI THỰC NGHIỆM.....	33
3.1. Mô hình thực nghiệm.....	33
3.2. Triển khai thực nghiệm các Playbook.....	34
3.2.1. Phát hiện hành vi sử dụng công cụ Mimikatz.....	34
3.2.2. Phát hiện file mã độc và tự động gỡ bỏ.....	39
3.2.3. Phát hiện tấn công ssh brute force và tự động block.....	47
3.3. Kết luận và đánh giá.....	53
PHỤ LỤC.....	55
TÀI LIỆU THAM KHẢO.....	60

DANH MỤC HÌNH ẢNH

Hình 1.1: SIEM.....	9
Hình 1.2:Elastic Stack.....	11
Hình 1.3: IBM Qradar.....	12
Hình 1.4: Splunk.....	13
Hình 1.5: Wazuh.....	13
Hình 2.1: Kiến trúc của Wazuh.....	18
Hình 2.2: Mô hình Cluster của Wazuh.....	19
Hình 2.3: Cơ chế Shard của Wazuh.....	22
Hình 2.4: Các thành phần của Wazuh Agent.....	24
Hình 2.5: Kiến trúc của Shuffle.....	27
Hình 2.6: Ví dụ về 1 workflow của Shuffle.....	30
Hình 3.1:Mô hình triển khai thực nghiệm.....	33
Hình 3.2:Workflow kịch bản 1.....	36
Hình 3.3: Workflow kịch bản 2.....	41
Hình 3.4:Workflow kịch bản 3.....	50

DANH MỤC BẢNG

Bảng 1: Các loại Index của Wazuh Indexer.....	22
Bảng 2: Một số port phổ biến.....	26

LỜI CẢM ƠN

Lời đầu tiên em xin gửi lời cảm chân thành đến thầy Hoàng Thanh Nam, giảng viên khoa An toàn thông tin – Học viện Kỹ thuật mật mã. Trong thời gian tham gia lớp học phần, thầy đã tạo điều kiện học tập, cung cấp đầy đủ các kiến thức cũng như học liệu của môn học, giúp em nắm vững được nền tảng cơ bản và mục tiêu của học phần. Đồng thời, thầy cũng đã tận tình hướng dẫn, giúp đỡ, đưa ra những lời khuyên cần thiết để em có thể hoàn thành đề tài này.

Em xin chân thành cảm ơn!

GIẢNG VIÊN HƯỚNG DẪN

ThS. Hoàng Thanh Nam

SINH VIÊN THỰC HIỆN

Nguyễn Đức Chiến

LỜI MỞ ĐẦU

Trong bối cảnh hiện nay, tình hình an ninh mạng tại Việt Nam diễn biến hết sức phức tạp: số lượng sự cố tấn công mạng năm 2024 đã vượt 659.000 sự cố tấn công mạng, ảnh hưởng đến gần một nửa số cơ quan, doanh nghiệp trong cả nước. Các hình thức tấn công không chỉ dừng lại ở mức độ đơn giản như quét scan hay brute-force mà ngày càng tinh vi hơn, có chủ đích hơn, nổi bật là tấn công Ransomware, tấn công APT (Advanced Persistence Threat), lừa đảo trực tuyến (Phishing) và chiếm quyền điều khiển hệ thống. Tiêu biểu nhất là vụ tấn công vào công ty dầu PVOIL vào năm 2024 có chủ đích dùng Ransomware mã hóa dữ liệu gây ra thiệt hại không hề nhỏ.

Trong bối cảnh các mối đe dọa ngày càng gia tăng, việc triển khai giải pháp giám sát an ninh mạng tập trung (SIEM) là cần thiết nhằm thu thập, phân tích log từ nhiều nguồn, phát hiện bất thường và cảnh báo kịp thời cho SOC. Wazuh là giải pháp SIEM mã nguồn mở tiêu biểu, cung cấp các chức năng như phân tích log, HIDS, giám sát tuân thủ, quản lý lỗ hổng và Threat Intelligence, phù hợp cho các tổ chức vừa và nhỏ. Để nâng cao khả năng phản ứng sự cố, Wazuh được kết hợp với Shuffle SOAR nhằm tự động hóa xử lý cảnh báo, làm giàu thông tin và thực hiện các hành động phản ứng như chặn IP hoặc cô lập hệ thống.

Việc kết hợp Wazuh (SIEM) và Shuffle (SOAR) giúp hình thành một hệ thống giám sát và ứng phó an ninh mạng tự động, linh hoạt và hiệu quả, góp phần nâng cao năng lực phòng thủ, giảm thời gian phản ứng sự cố và hạn chế tối đa thiệt hại cho tổ chức trước các mối đe dọa ngày càng gia tăng hiện nay.

CHƯƠNG 1 : CƠ SỞ LÝ THUYẾT

1.1. Giám sát an toàn mạng thông tin trong mạng máy tính

1.1.1. Tình hình an toàn thông tin trong mạng máy tính hiện nay

Hiện nay, vấn đề an toàn thông tin (ATTT) trong mạng máy tính đối mặt với nhiều thách thức nghiêm trọng do sự gia tăng cả về quy mô lẫn tính phức tạp của các cuộc tấn công mạng. Các cuộc tấn công DDoS và ransomware gia tăng (25% và 81% trong 2 năm qua), Tấn công lừa đảo qua email và tin nhắn (phishing, vishing) chiếm tới 85% sự cố di động, đặc biệt tập trung vào ngành tài chính với số lượng thử nghiệm phishing cao gấp 5 lần các ngành khác. Ngoài ra, các lỗ hổng từ thiết bị IoT có bảo mật yếu và cấu hình sai sót trong môi trường đám mây (tăng 154% trong năm qua) tạo ra những điểm yếu dễ bị khai thác, sự áp dụng AI trong tấn công (mã độc tự học, zero-day) mở rộng bề mặt tấn công.

Thách thức lớn tiếp theo là sự phức tạp của mạng hiện đại, với sự mở rộng bề mặt tấn công do chuyển đổi sang môi trường đa đám mây, làm việc từ xa, và tích hợp IoT, khiến việc bảo vệ trở nên khó khăn hơn so với mô hình mạng truyền thống. Bên cạnh đó, tình trạng thiếu hụt nhân lực an ninh mạng, với lực lượng toàn cầu đạt 4,7 triệu người nhưng vẫn tồn tại khoảng cách kỹ năng (59% chuyên gia rời bỏ công việc do được tuyển dụng bởi các tổ chức khác), cùng với việc chỉ 42% tổ chức cho rằng ngân sách ATTT của họ đủ đáp ứng, là những rào cản đáng kể. Áp lực tuân thủ các quy định quốc tế như GDPR và HIPAA, trong khi 82% giám đốc an ninh thông tin (CISO) sẵn sàng làm "người tố giác" nếu tổ chức cố tình bỏ qua vấn đề bảo mật, càng làm tăng tính cấp bách của vấn đề

1.1.2. Các mối đe dọa và lỗ hổng phổ biến

- Tấn công DDoS (Distributed Denial of Service): Các cuộc tấn công từ chối dịch vụ phân tán gia tăng 25% trong nửa đầu năm 2025, sử dụng đa vector để làm gián đoạn dịch vụ, đặc biệt nhắm vào các tổ chức tài chính và thương mại điện tử.
- Ransomware: Loại mã độc tống tiền tăng 81% từ 2023-2024, với hình thức tống tiền kép (mã hóa dữ liệu và đe dọa lộ thông tin), gây thiệt hại hàng tỷ USD, đặc biệt trong các ngành y tế và giáo dục.

- Phishing và Social Engineering: Chiếm 85% sự cố trên thiết bị di động, bao gồm lừa đảo qua email, tin nhắn (vishing), và mạng xã hội, với ngành tài chính chịu gánh nặng gấp 5 lần các ngành khác do thử nghiệm phishing liên tục.
- Tấn công Zero-Day: Lỗ hổng chưa được vá bị khai thác ngay khi phát hiện, với số lượng tăng 30% trong năm qua, nhắm vào các phần mềm phổ biến như Windows và Adobe.
- Lỗ Hổng từ Thiết Bị IoT: Thiết bị Internet of Things (IoT) với bảo mật yếu, cấu hình sai sót, và phần mềm không cập nhật, tạo ra hơn 50% các điểm tấn công trong mạng doanh nghiệp.
- Lỗi Cấu Hình Đám Mây: Tăng 154% trong năm 2024-2025, bao gồm quyền truy cập không giới hạn, lưu trữ không mã hóa, và thiếu kiểm soát trong môi trường đa đám mây.
- Lỗ Hổng Ứng Dụng Web: Tiếp tục chiếm 40% các cuộc tấn công, với các lỗi như SQL Injection, Cross-Site Scripting (XSS), và Broken Authentication trong các ứng dụng không được vá kịp thời.
- Lỗ Hổng Hệ Điều Hành: Các hệ điều hành như Windows, Linux, và iOS thường xuyên bị nhắm đến do cập nhật chậm, với hơn 60% thiết bị doanh nghiệp chưa áp dụng bản vá trong vòng 30 ngày.

1.1.3. Nhu cầu giám sát và ứng phó sự cố bảo mật

Vậy, từ tình hình an toàn thông tin trong mạng máy tính hiện nay, có thể thấy được sự cần thiết của việc giám sát và ứng phó các sự cố bảo mật là yếu tố cốt lõi để duy trì an toàn trong môi trường mạng hiện đại. Và để nâng cao hiệu quả quản lý, hỗ trợ đáp ứng các yêu cầu pháp lý nghiêm ngặt trong việc bảo vệ dữ liệu, các hệ thống như SOAR, SIEM sẽ là trợ thủ đắc lực trong việc đảm bảo khả năng chống chịu trước các thách thức an ninh mạng, góp phần xây dựng một môi trường số an toàn, bền vững.

1.2. Tổng quan về Security Information and Event Management (SIEM)

1.2.1. Khái niệm về SIEM

SIEM là một phần mềm kết hợp giữa SIM (thu thập, phân tích và báo cáo dữ liệu nhật ký từ các thiết bị bảo mật) và SEM (thu thập, phân tích và báo cáo các sự kiện liên quan đến bảo mật trong một phần mềm, hệ thống hoặc môi trường CNTT theo thời gian thực) để giám sát mối đe dọa và ứng phó sự cố. Chính vì vậy, giải pháp SIEM cung cấp khả năng giám sát và phân tích các sự kiện theo thời gian thực cũng như theo dõi và ghi lại dữ liệu bảo mật giúp tăng cường khả năng phát hiện mối đe dọa, tuân thủ và quản lý sự cố bảo mật.



Hình 1.1: SIEM

1.2.2. Cách thức hoạt động của SIEM

Hệ thống SIEM hoạt động thông qua một quy trình gồm nhiều bước, từ việc thu thập dữ liệu, phân tích, đến phát hiện và phản ứng với các mối đe dọa an ninh mạng.

- Thu thập dữ liệu từ nhiều nguồn

SIEM bắt đầu bằng việc thu thập dữ liệu bảo mật (nhật ký sự kiện (log), thông tin truy cập và hoạt động của người dùng) từ nhiều nguồn khác nhau trong hệ thống, bao gồm:

- ❖ Thiết bị mạng: Tường lửa (firewall), router và switch.
- ❖ Hệ thống endpoint: Máy chủ, máy tính cá nhân và thiết bị IoT.

- ❖ Ứng dụng và cơ sở dữ liệu: Dữ liệu nhật ký từ các ứng dụng doanh nghiệp, cơ sở dữ liệu và hệ thống quản lý.
- ❖ Các công cụ bảo mật khác: Hệ thống phát hiện xâm nhập (IDS/IPS), phần mềm diệt virus và giải pháp VPN.

- Chuẩn hóa và lưu trữ dữ liệu

Sau khi thu thập, dữ liệu được chuẩn hóa để đảm bảo định dạng nhất quán, dễ dàng cho việc phân tích. Công cụ SIEM sử dụng cơ sở dữ liệu lớn (big data) để lưu trữ dữ liệu này, đồng thời áp dụng các phương pháp nén và tối ưu hóa để tiết kiệm tài nguyên lưu trữ.

- Phân tích và xử lý dữ liệu

Dữ liệu sau khi lưu trữ sẽ được phân tích thông qua các công nghệ như:

- ❖ So sánh mẫu (Pattern Matching): Đối chiếu dữ liệu với các mẫu hành vi đã biết để phát hiện dấu hiệu của các cuộc tấn công mạng.
- ❖ Phân tích hành vi (Behavioral Analysis): Nhận diện các hành vi bất thường của người dùng hoặc hệ thống dựa trên lịch sử hoạt động.
- ❖ Học máy (Machine Learning): Dự đoán các mối đe dọa tiềm ẩn bằng cách học từ các xu hướng và dữ liệu trước đó.

Quá trình này giúp SIEM phát hiện các mối đe dọa phức tạp mà các công cụ bảo mật thông thường khó nhận biết như các cuộc tấn công zero-day hoặc các hành vi nội gián nguy hiểm.

- Tạo cảnh báo và báo cáo

Khi phát hiện các mối đe dọa hoặc hành vi bất thường, SIEM sẽ gửi cảnh báo đến nhóm bảo mật thông qua nhiều kênh như email, tin nhắn hoặc dashboard trực quan. Mức độ nghiêm trọng của các cảnh báo được phân loại để đội ngũ có thể ưu tiên xử lý.

Ngoài ra, hệ thống SIEM cung cấp các báo cáo chi tiết về tình trạng an ninh mạng, bao gồm:

- ❖ Phân tích sự cố: Đánh giá nguyên nhân và tác động của sự cố an ninh.
- ❖ Báo cáo tuân thủ: Hỗ trợ doanh nghiệp đáp ứng các tiêu chuẩn bảo mật như ISO 27001, PCI DSS, hoặc GDPR.

- Tích hợp phản ứng tự động

Các công cụ SIEM hiện đại không chỉ dừng lại ở việc phát hiện mà còn tích hợp khả năng phản ứng tự động với các sự cố, hạn chế tối đa thiệt hại từ các cuộc tấn công. Ví dụ:

- ❖ Chặn IP hoặc cô lập thiết bị bị xâm nhập.
- ❖ Khóa tài khoản người dùng có hành vi đáng ngờ.
- ❖ Gửi lệnh khắc phục sự cố tới các hệ thống bảo mật khác.

1.2.3. Một số giải pháp SIEM nổi bật

1.2.3.1. ELK Stack

ELK Stack là công cụ mã nguồn mở phổ biến nhất hiện nay. Nó là một phần kiến trúc của Apache Metron, SIEMonster và Wazuh. Nó bao gồm nhiều sản phẩm SIEM miễn phí: Elasticsearch, Logstash, Kibana.

- Elasticsearch: Lập các index và lưu trữ dữ liệu và sử dụng cơ chế xếp hàng để các kết nối dữ liệu được duy trì.
- Logstash: Tiếp nhận log từ nhiều nguồn khác nhau và chuẩn hóa dữ liệu thu được và ghi dữ liệu vào Elasticsearch.
- Kibana: Cung cấp giao diện trực quan hóa dữ liệu cho người dùng.
- Beats: Một tập các công cụ thu thập, vận chuyển thông tin chuyên dụng từ máy khách tới máy chủ ELK.



elastic stack

Hình 1.2:Elastic Stack

1.2.3.2. IBM Qradar

IBM Qradar là một giải pháp tổng thể, hoạt động như một trung tâm giám sát, bảo mật cho cơ quan tổ chức. Với giao diện người dùng trực quan được tích hợp với nhiều sản phẩm của IBM nói riêng và các hãng công nghệ khác khiến giải pháp QRadar là giải pháp toàn diện cho hệ thống. Trong QRadar SIEM, công cụ phân tích Sense Analytics Engine là trung tâm của giải pháp dùng để ghi nhận các sự kiện, log thời gian thực cũng như các luồng dữ liệu qua hệ thống mạng. Qua đó có thể phát hiện được các lỗ hổng bảo mật, xâm nhập trái phép từ bên ngoài. QRadar SIEM có thể triển khai cài đặt đơn giản, dễ dàng cùng với khả năng mở rộng, hợp nhất dữ liệu thu thập được từ nhiều nguồn giúp nhanh chóng xác định và khắc phục các cuộc tấn công.

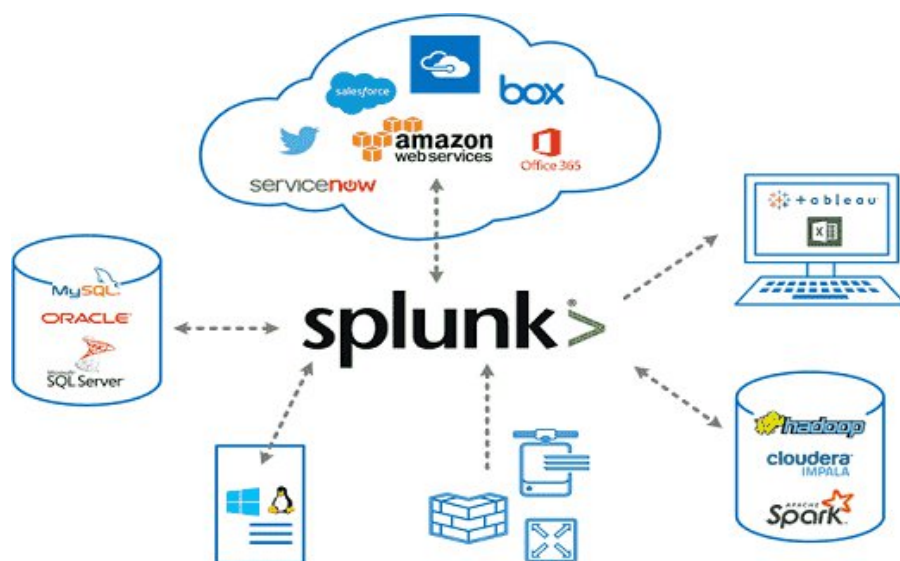


Hình 1.3: IBM Qradar

1.2.3.3. Splunk

Splunk là một phần mềm giám sát mạng dựa trên sức mạnh của việc phân tích Log. Splunk thực hiện các công việc tìm kiếm, giám sát và phân tích các dữ liệu lớn được sinh ra từ các ứng dụng, các hệ thống và các thiết bị hạ tầng mạng. Nó có thể thao tác tốt với nhiều loại định dạng dữ liệu khác nhau như syslog, csv, apache-log, access_combined. Splunk được xây dựng dựa trên nền tảng Lucene and MongoDB. Splunk rất tốt cho các công ty sử dụng Hadoop để theo dõi và lưu trữ dữ liệu máy móc. Khi hệ thống Hadoop già cỗi, việc trích xuất những insights cần thiết từ chương trình này có thể tốn thời gian hoặc thậm chí không thể. Splunk Hunk tích hợp với Hadoop để tạo ra những hình ảnh mà bình thường không thể thực hiện được với các tập dữ liệu dựa trên Hadoop. Chỉ số ảo của Splunk phân tách khu lưu trữ dữ liệu, làm cho việc phân tích và tạo bảng điều khiển đơn giản hơn. Giống như nền tảng đám mây của Splunk, Splunk Hunk xử lý dữ liệu không cấu trúc mà không cần định dạng

thủ công, điều này rất quan trọng đối với người dùng Hadoop đang làm việc với một lượng lớn dữ liệu thô.



Hình 1.4: Splunk

1.2.3.4. Wazuh

Wazuh là một nền tảng bảo mật mã nguồn mở mạnh mẽ, được thiết kế để giám sát và phân tích các hoạt động hệ thống. Hệ thống thu thập log từ nhiều nguồn khác nhau như máy chủ, ứng dụng và thiết bị mạng, từ đó xử lý dữ liệu log để nhận diện các dấu hiệu bất thường. Nó hỗ trợ phát hiện xâm nhập và các mối đe dọa an ninh mạng thông qua các quy tắc và chữ ký bảo mật được cập nhật liên tục. Wazuh cho phép giám sát an ninh theo thời gian thực và kiểm tra đánh giá cấu hình hệ thống nhằm đảm bảo an toàn tối đa. Đồng thời, nó hỗ trợ đánh giá tuân thủ các tiêu chuẩn bảo mật nội bộ và quốc tế, góp phần củng cố tính toàn vẹn của hệ thống

wazuh.

Hình 1.5: Wazuh

1.3. Tổng quan về Security Orchestration, Automation and Response(SOAR)

1.3.1. Khái niệm về SOAR

SOAR (Security Orchestration, Automation, and Response) là một giải pháp công nghệ tích hợp nhằm tối ưu hóa quy trình quản lý an ninh mạng thông qua việc phối hợp (orchestration), tự động hóa (automation), và phản ứng (response) với các sự cố bảo mật. Xuất hiện như một bước tiến vượt bậc trong lĩnh vực an ninh mạng, SOAR giúp các tổ chức giảm thiểu thời gian phát hiện và ứng phó với mỗi đe dọa, từ đó nâng cao hiệu quả hoạt động của đội ngũ bảo mật. Khái niệm này được xây dựng dựa trên việc tận dụng dữ liệu từ nhiều nguồn, sử dụng trí tuệ nhân tạo và các công cụ phân tích để tự động hóa các tác vụ lặp đi lặp lại, đồng thời hỗ trợ ra quyết định dựa trên thông tin thực tế.

1.3.2. Thành phần và chức năng chính của một hệ thống SOAR

1.3.2.1. Lớp điều phối (Orchestration Layer)

Lớp này đóng vai trò trung gian kết nối và tích hợp nhiều công cụ bảo mật khác nhau như SIEM, IDS/IPS, firewall, hệ thống quản lý endpoint, cơ sở dữ liệu threat intelligence, và hệ thống quản lý ticket. Việc điều phối giúp hợp nhất thông tin từ nhiều nguồn và đảm bảo các hành động xử lý được phối hợp nhất quán, theo đúng quy trình đã định.

1.3.2.2. Bộ máy tự động hóa (Automation Engine)

Thành phần này chịu trách nhiệm thực thi các tác vụ lặp lại thông qua kịch bản định nghĩa sẵn (playbook), nhằm giảm thiểu sự can thiệp thủ công. Ví dụ, khi phát hiện IP độc hại, hệ thống có thể tự động kiểm tra trên nhiều nguồn threat intelligence, cảnh báo quản trị viên và thực hiện hành động chặn trên firewall.

1.3.2.3. Quản lý sự cố (Incident & Case Management)

SOAR cung cấp giao diện và cơ chế để tạo, theo dõi và quản lý từng sự cố an toàn thông tin dưới dạng hồ sơ (case). Người dùng có thể thêm ghi chú, phân công nhiệm vụ, cập nhật tiến độ và lưu trữ lịch sử xử lý. Điều này hỗ trợ việc truy vết và đánh giá hậu kỳ sau khi sự cố được giải quyết.

1.3.2.4. Kịch bản phản ứng (Playbook Engine)

Playbook là tập hợp các bước xử lý có cấu trúc, được định nghĩa trước để phản ứng với từng loại sự cố cụ thể (ví dụ: xử lý email giả mạo, mã độc, xâm nhập trái

phép...). Playbook có thể được xây dựng thông qua giao diện trực quan hoặc dưới dạng mã lệnh tùy theo hệ thống SOAR cụ thể.

1.3.2.5. Tích hợp nguồn tin đe dọa (Threat Intelligence Integration)

Hệ thống SOAR thường tích hợp với các nền tảng cung cấp thông tin về mối đe dọa (threat intelligence) nhằm hỗ trợ việc phân tích và ra quyết định. Qua đó, các chỉ báo tấn công (IOC) như địa chỉ IP, tên miền, mã băm (hash) có thể được kiểm tra để xác định mức độ nguy hiểm và đối sách phù hợp.

1.3.2.6. Giao diện hiển thị và báo cáo (Dashboard & Reporting)

SOAR cung cấp giao diện đồ họa giúp theo dõi thời gian thực các sự cố đang diễn ra, đánh giá hiệu suất hệ thống, cũng như xuất báo cáo phục vụ quản lý và tuân thủ. Đây là công cụ hữu ích để hỗ trợ ra quyết định chiến lược trong công tác an toàn thông tin.

1.3.3. Cách thức hoạt động

- Phân tích và chuẩn hóa dữ liệu, đánh giá ưu tiên

Khi nhận cảnh báo, hệ thống SOAR thực hiện phân tích và chuẩn hóa (normalize) dữ liệu liên quan. Các playbook trong SOAR sẽ phân tích cú pháp và chuyển đổi thông tin sự kiện về định dạng thống nhất để dễ dàng xử lý. Đồng thời, SOAR thực hiện bổ sung ngữ cảnh (enrichment) cho dữ liệu: tự động tra cứu các chỉ số IOC (ví dụ địa chỉ IP, tên miền, hash file) trên các nguồn threat intelligence như VirusTotal, WHOIS hay MITRE ATT&CK. Việc này giúp xác định nhanh các mối đe dọa liên quan và đánh giá mức độ nghiêm trọng của sự cố. Kết hợp với việc đối chiếu dữ liệu lịch sử từ SIEM hoặc các nguồn thông tin nội bộ, SOAR sẽ xác định mức ưu tiên xử lý cho từng sự kiện, sẵn sàng kích hoạt kịch bản ứng phó thích hợp.

- Kích hoạt Playbook ứng phó

Dựa trên kết quả phân tích sự kiện và các quy tắc định nghĩa sẵn, SOAR kích hoạt playbook (cẩm nang xử lý) tương ứng. Mỗi playbook là một kịch bản tác vụ (workflow) bao gồm các bước thực thi logic có điều kiện. Playbook được định nghĩa trước có thể chạy tự động khi một cảnh báo hoặc sự kiện thỏa điều kiện đã thiết lập. Trong playbook này, hệ thống có thể phân nhánh theo điều kiện (if-then), lặp vòng, hoặc chờ phê duyệt của con người trước các bước nhạy cảm. Việc sử dụng playbook cho phép tự động hóa toàn bộ luồng xử lý sự cố theo kịch bản đã được chuẩn hóa.

- Tự động hóa hành động phản ứng

Khi playbook được kích hoạt, SOAR sẽ tự động thực thi các hành động phản ứng bảo mật theo quy trình. Các bước điển hình bao gồm:

- ❖ Tra cứu thông tin IOC và tình báo mối đe dọa: Playbook có thể tự động trích xuất các IOC (IP, domain, hash) từ cảnh báo và tra cứu dữ liệu trên VirusTotal, WHOIS, Passive DNS hay cơ sở dữ liệu MITRE để bổ sung bối cảnh. Việc này giúp xác định nhanh tính độc hại của sự kiện.
- ❖ Cô lập và vô hiệu hóa đối tượng bị nghi ngờ: Nếu xác định có thiết bị hoặc tài khoản bị xâm phạm, hệ thống có thể tự động vô hiệu hóa tài khoản người dùng, cô lập endpoint (isolating host) trong hệ thống EDR/NDR hoặc ngắt kết nối khỏi mạng để ngăn mối đe dọa lan rộng.
- ❖ Ngăn chặn mối đe dọa: Các IOC nguy hiểm (như IP hoặc URL độc hại) được tự động chặn trên tường lửa, proxy, cổng email hoặc tại các giải pháp bảo mật liên quan. Ví dụ, IP độc hại được chặn trên firewall, mã độc được cách ly/quarantine trong EDR, hoặc URL phishing bị đen danh sách trên cổng email.
- ❖ Thông báo và khởi tạo ticket: Đồng thời, SOAR tự động gửi cảnh báo (qua email, hệ thống chat bảo mật, SMS...) tới nhóm SOC và tạo/tự động cập nhật ticket sự cố trong hệ thống quản lý công việc (ITSM). Nhờ vậy, mọi người liên quan đều nhận được thông tin kịp thời và công tác phối hợp được duy trì.
- ❖ Các hành động trên được thực hiện ở tốc độ máy, giúp rút ngắn thời gian phản ứng và giảm tải cho nhân sự. Toàn bộ thao tác dù có tự động hay cần sự can thiệp của con người đều được ghi lại chi tiết trong quy trình.

- Ghi lại quy trình và quản lý sự cố (Case Management)

SOAR tích hợp chức năng quản lý sự cố (case management) để lưu trữ và theo dõi toàn bộ tiến trình ứng phó. Mỗi cảnh báo được tạo thành hồ sơ sự cố (case) riêng, trong đó SOAR tập trung tổ chức các thông tin liên quan như alerts, artifacts (IOC), kết quả kiểm tra và ghi chú của chuyên gia vào cùng một giao diện duy nhất. Hệ thống tự động đánh dấu thời gian và lưu trữ từng bước xử lý – cả bước tự động lẫn thao tác thủ công – để đảm bảo tính toàn vẹn và khả năng truy xuất của hồ sơ. Các

case có thể được đóng, tái mở hoặc chuyển cấp (escalate) dựa theo logic của playbook (ví dụ nếu phát hiện thêm bằng chứng mới thì tái kích hoạt, hoặc tự động đóng nếu sự kiện không nguy hiểm). Nhờ vậy, hoạt động ứng phó luôn có hồ sơ minh bạch, dễ dàng báo cáo và theo dõi mức độ tuân thủ SLA.

- Báo cáo và đánh giá sau sự cố

Cuối cùng, SOAR hỗ trợ tổng hợp và đánh giá sau sự cố thông qua báo cáo và dashboard. Hệ thống tự động tạo các báo cáo tình huống tổng quan, biểu đồ giám sát cho các chỉ số quan trọng (ví dụ số lượng sự cố theo thời gian, MTTR, SLA, tỷ lệ false positive...). Ví dụ, các dashboard có thể hiển thị xu hướng mối đe dọa và hiệu suất xử lý của SOC, giúp lãnh đạo nắm bắt toàn cảnh bảo mật. Bên cạnh đó, việc tự động hóa báo cáo đảm bảo rằng nhóm bảo mật nhận được các số liệu và phân tích định kỳ một cách nhanh chóng và chính xác. Dữ liệu chi tiết từ quá trình ứng phó (log sự kiện, kết quả enrichment, hành động khắc phục) được sử dụng để đánh giá hiệu quả, điều chỉnh playbook và cải tiến quy trình liên tục sau mỗi sự cố.

CHƯƠNG 2 : XÂY DỰNG GIẢI PHÁP HỆ THỐNG SOAR

2.1. Giới thiệu về Wazuh

2.1.1. Tổng quan về Wazuh

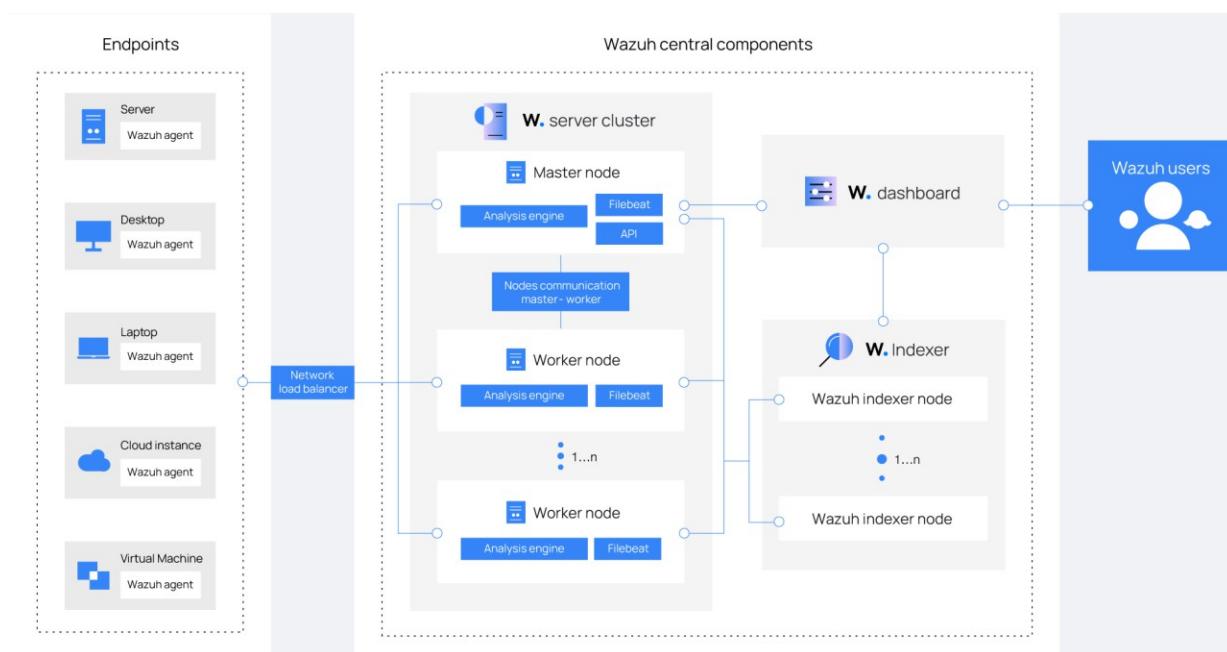
Wazuh là nền tảng bảo mật mã nguồn mở mạnh mẽ, cung cấp khả năng giám sát, phát hiện xâm nhập và phân tích sự cố bảo mật. Năm 2014, OSSEC được tái cấu trúc và đổi tên thành Wazuh, mở rộng tính năng để đáp ứng yêu cầu bảo mật phức tạp hơn. Từ 2017 đến 2020, Wazuh phát triển mạnh mẽ nhờ sự đóng góp của cộng đồng bảo mật, bổ sung giám sát đám mây và tích hợp với ELK Stack. Đến 2021, WAZUH tiếp tục cải tiến với các tính năng mới như giám sát container, phân tích mã nguồn và tích hợp trí tuệ nhân tạo (AI) và machine learning.

Wazuh là một nền tảng bảo mật cung cấp bảo vệ XDR và SIEM thống nhất cho các điểm cuối và khối lượng công việc đám mây. Giải pháp bao gồm một tác nhân chung duy nhất và ba thành phần trung tâm: máy chủ Wazuh, trình lập chỉ mục Wazuh và bảng điều khiển Wazuh. Wazuh là một nền tảng bảo mật mã nguồn mở và miễn phí, hợp nhất các khả năng của XDR và SIEM. Các thành phần của nó tuân thủ

theo Giấy phép Công cộng GNU, phiên bản 2 và Giấy phép Apache, phiên bản 2.0 (ALv2). Nó bảo vệ khối lượng công việc trên các môi trường tại chỗ, ảo hóa, chứa và dựa trên đám mây. Wazuh giúp các tổ chức và cá nhân bảo vệ tài sản dữ liệu của họ khỏi các mối đe dọa bảo mật. Nó được sử dụng rộng rãi bởi hàng ngàn tổ chức trên toàn thế giới, từ các doanh nghiệp nhỏ đến các doanh nghiệp lớn.

2.1.2. Kiến trúc của Wazuh

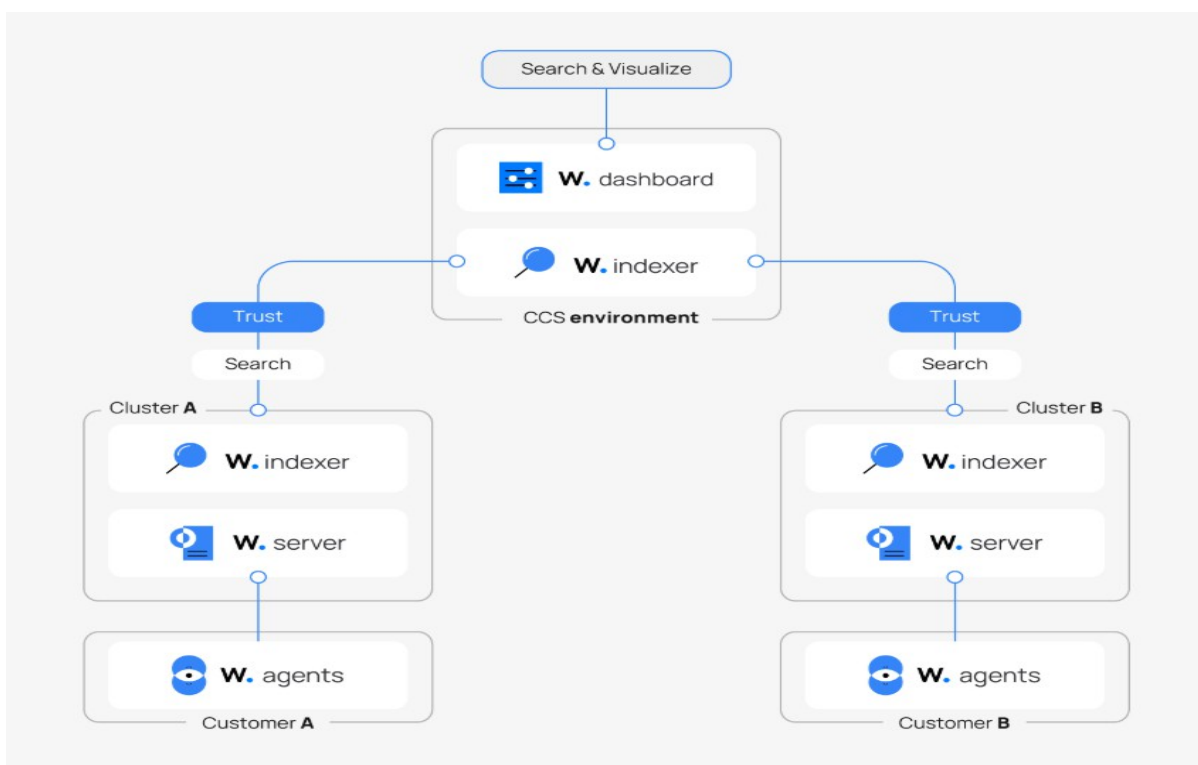
Một kiến trúc Wazuh được cấu thành từ Agent Wazuh đa nền tảng (Multi-Platform) và 3 thành phần trung tâm đó là: Wazuh Server, Wazuh Indexer và Wazuh Dashboard. Agent được cài đặt trên các thiết bị đầu cuối (Endpoints) để thu thập và chuyển tiếp dữ liệu an ninh đến Wazuh Server cho việc phân tích. Những dữ liệu đã được phân tích lại được chuyển tiếp lên Wazuh Indexer cho việc chỉ mục và lưu trữ log, trong khi đó Wazuh dashboard sẽ đóng vai trò cảnh báo và trực quan hóa dữ liệu đây sẽ là nơi người dùng tương tác trực tiếp.



Hình 2.1: Kiến trúc của Wazuh

Các thành phần trung tâm kể trên có thể được triển khai theo nhiều hướng khác nhau, chủ yếu phụ thuộc vào hai nhu cầu mở rộng (scalability) và tính sẵn sàng (Availability). Sau đây là 3 hướng triển khai của một kiến trúc Wazuh:

- All-in-one deployment: Tất cả các thành phần trung tâm Wazuh (Server, Indexer, và Dashboard) đều được cài đặt trên cùng một node. Rất phù hợp cho việc triển khai môi trường lab với số lượng các Endpoints cần giám sát có giới hạn.
- Single-Node deployment: Wazuh Server, Indexer và Dashboard đều được triển khai trên một máy chủ riêng biệt (Tức mỗi máy phục vụ riêng 1 chức năng). Phù hợp cho môi trường tầm trung thứ mà ưu tiên hiệu năng xử lý so với việc deploy cả 3 thành phần trên cùng một máy như mô hình All-in-one deployment.
- Multi-node deployment: Thông thường, một instance của Wazuh dashboard và nhiều instance của Wazuh server (cụm Wazuh server) cũng như indexer (cụm Wazuh indexer) sẽ được triển khai trên các máy chủ riêng biệt tương ứng. Số lượng instance có thể thay đổi tùy theo nhu cầu của doanh nghiệp. Kiểu triển khai này được khuyến nghị cho các môi trường lớn có lưu lượng sự kiện cao, hoặc khi cần khả năng chịu lỗi (Fault Tolerance và tính sẵn sàng cao (High Availability)).



Hình 2.2: Mô hình Cluster của Wazuh

2.1.3. Các thành phần và chức năng của Wazuh

2.1.3.1. Wazuh Server

Bao gồm nhiều thành phần con với nhiều chức năng khác nhau, như là triển khai agent mới, xác thực lại agent cũng như là mã hóa kênh liên lạc giữa Wazuh Agent và Wazuh Server.

- Agent enrollment service: Được dùng để đăng ký Agent. Dịch vụ này cung cấp và phân phát các khóa xác thực độc nhất (Authentication keys) với mỗi Agent được deploy. Tiến trình này chạy như là một dịch vụ mạng và cung cấp xác thực thông qua chứng chỉ TLS/SSL bằng cung cấp một mật khẩu đã định sẵn.
- Agent connection service: Dịch vụ này nhận dữ liệu từ Agents. Nó sử dụng authentication keys cung cấp bởi dịch vụ enrollment service để xác nhận danh tính của Agent và mã hóa giao tiếp giữa Wazuh Agent và Wazuh Server. Thêm vào đó còn cung cấp quản lý cấu hình tập trung cho phép người quản trị có thể đẩy cài đặt (Settings) lên Agent từ xa.
- Analysis Engine: Sử dụng các bộ decoders để xác minh loại log hay dữ liệu khi đang được xử lý (Windows Events, SSH logs, Web server logs, và các loại log khác). Những bộ decoders này còn có thể trích xuất những yếu tố dữ liệu liên quan từ log message, như là IP nguồn, IP đích, event ID, hay username. Từ đó, kết hợp với bộ luật tích hợp sẵn, Engine có thể xác minh được các đặc trưng cụ thể trong những sự kiện đã được decode những sự kiện mà có thể gây cảnh báo và thậm chí có thể gọi lên cái hệ thống phòng thủ tự động để chặn IP độc hại, dừng tiến trình bất hợp pháp và xóa Malware độc hại.
- Wazuh RESTful API: Cung cấp Interface để tương tác với cơ sở hạ tầng Wazuh. Nó được dùng để quản lý cấu hình cài đặt của Agents và Servers, theo dõi trạng thái sức khỏe của hệ thống hay là quản lý và chỉnh sửa bộ decoders của Wazuh hoặc luật, đồng thời có thể thực hiện

truy vấn theo dõi trạng thái của các máy Agents. Wazuh Dashboard cũng có thể sử dụng các chức năng đó.

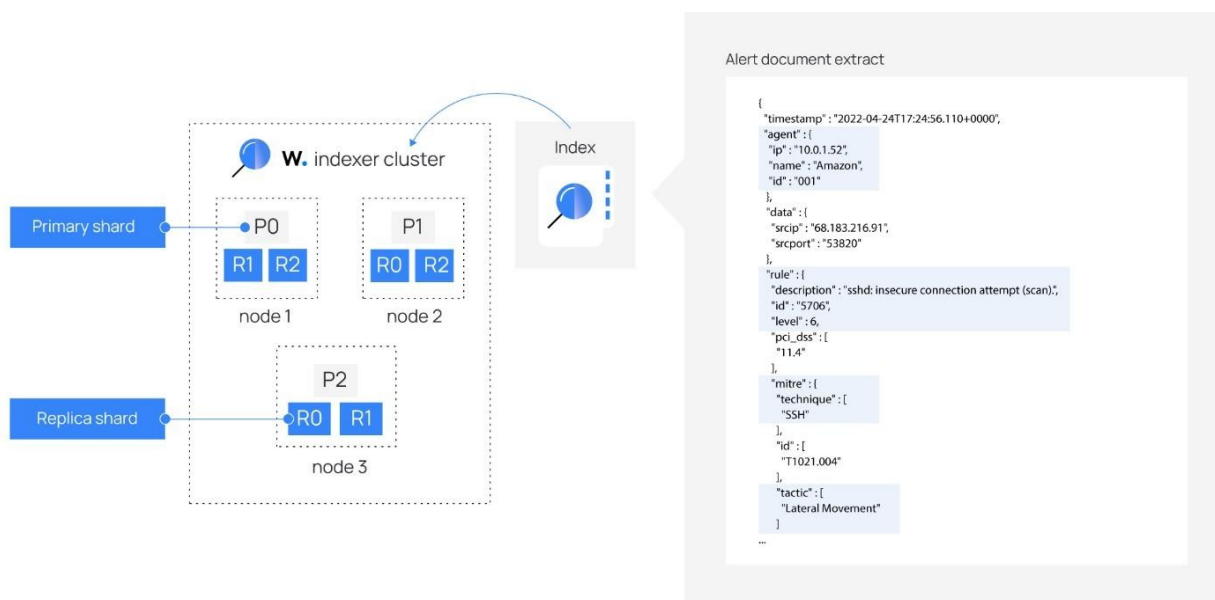
- Wazuh cluster daemon: Cho phép mở rộng môi trường Wazuh Servers, trải khai môi trường dưới dạng cluster. Kết hợp với network load balancer, cung cấp tính sẵn sàng cao và khả năng chịu tải. Wazuh cluster daemon là cái mà Wazuh Server sử dụng để giao tiếp với nhau cũng như giữ cho chúng đồng bộ.
- Filebeat: Đóng vai trò như là người vận chuyển tất cả các events, raw logs sẽ đều là do Filebeat truyền lên Wazuh Indexer để thực hiện cái trình parsing log.

2.1.3.2. Wazuh Indexer

Là một công cụ phân tích và tìm kiếm toàn văn có khả năng mở rộng cao. Đây là thành phần trung tâm của Wazuh, có nhiệm vụ lập chỉ mục và lưu trữ các cảnh báo do Wazuh Server tạo ra, đồng thời cung cấp khả năng tìm kiếm và phân tích dữ liệu gần như theo thời gian thực. Wazuh Indexer có thể được cấu hình dưới dạng một node đơn lẻ (Single-Node) hoặc cụm nhiều node (Multi-Node), nhằm đảm bảo khả năng mở rộng và tính sẵn sàng cao.

Wazuh Indexer lưu trữ dữ liệu dưới dạng tài liệu JSON. Mỗi tài liệu bao gồm một tập hợp các khóa, tên trường hoặc thuộc tính, cùng với các giá trị tương ứng, có thể là chuỗi số, số boolean, ngày giờ, mảng giá trị, vị trí địa lý hoặc các loại dữ liệu khác.

Index (chỉ mục) là một tập hợp các tài liệu có liên quan đến nhau. Các tài liệu được phân bổ trên nhiều shard (mảnh dữ liệu). Việc phân bổ tài liệu qua nhiều shard, và phân bổ các shard này lên nhiều node, giúp Wazuh Indexer đảm bảo được tính dự phòng. Điều này bảo vệ hệ thống khỏi sự cố phần cứng và đồng thời tăng khả năng xử lý truy vấn khi thêm node vào cluster.



Hình 2.3: Cơ chế Shard của Wazuh

Wazuh sử dụng bốn loại Index khác nhau để lưu trữ các loại sự kiện khác nhau:

Index	Mô tả
Wazuh-Alerts	Lưu trữ các alert được tạo ra bởi Wazuh Server. Những Alert này được tạo ra mỗi khi có một sự kiện kích hoạt luật của Wazuh với độ ưu tiên tương ứng (Độ ưu tiên hiểu đơn giản hơn là level của sự kiện có thể cấu hình và thay đổi được).
Wazuh-archives	Lưu trữ các sự kiện nhận bởi Wazuh Server, cho dù có kích hoạt luật hay không.
Wazuh-monitoring	Lưu trữ dữ liệu liên quan đến tình trạng của Wazuh Agent theo thời gian. Dữ liệu này được sử dụng bởi web interface (Wazuh Dashboard) để trình bày khi mà các Agent đang ở các trạng thái như là <i>Active</i> , <i>Disconnected</i> hoặc <i>Never connected</i> .
Wazuh-statistics	Lưu trữ dữ liệu liên quan đến hiệu suất của Wazuh Server. Dữ liệu này cũng được sử dụng bởi web interface (Wazuh Dashboard) để trình bày thông số hiệu năng.

Bảng 1: Các loại Index của Wazuh Indexer

2.1.3.3. Wazuh Dashboard

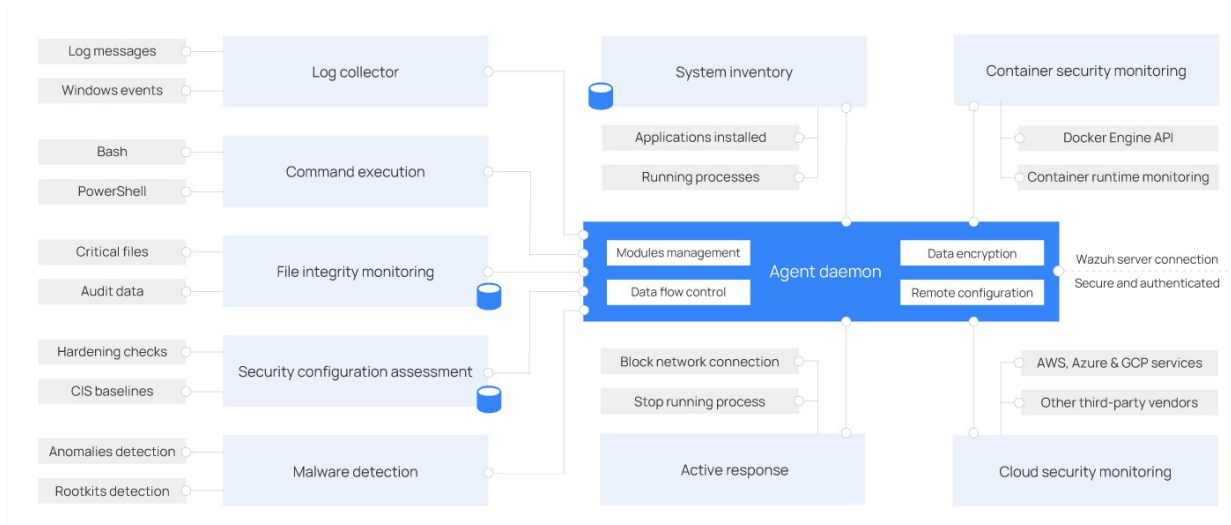
Wazuh Dashboard là một web interface linh hoạt trong việc khai thác, phân tích và trực quan hóa các sự kiện an ninh mạng và cảnh báo dữ liệu. Nó cũng được dùng như là giao diện quản lý và giám sát trên nền tảng Wazuh. Sau đây là những chức năng mà có thể thực hiện được trên Wazuh Dashboard:

- **Cấu hình và giám sát Agent:** cho phép người quản trị có thể thay đổi cấu hình của agent hay còn gọi là endpoint ngay trên Dashboard thay vì phải trực tiếp truy cập vào từng Agent một để cấu hình như là ta muốn cấu hình module nào của agent mà ta muốn chạy hay loại log nào sẽ được parsing và đẩy lên Wazuh Dashboard, thậm chí giám sát loại file nào tính toán vện...
- **Quản lý nền tảng (Platform management):** cho phép giám sát trạng thái, logs, và thông số của các thành phần Wazuh khác nhau. Nó còn bao gồm cấu hình Wazuh Server , và tạo rules custom và bộ decoders cho việc phân tích log và phát hiện mối hiểm họa.
- **Developer Tools:** cung cấp Ruleseet tool có thể giúp xử lý log message để kiểm tra xem bộ log được giải mã như nào và kiểm tra xem liệu rule có xảy ra khi nó khớp với một sự kiện an ninh hay không.

2.1.3.4. Wazuh Agent

Wazuh Agent có nguyên một kiến trúc dạng module. Mỗi thành phần đảm nhận một nhiệm vụ riêng, bao gồm giám hệ thống file, đọc log , thu thập dữ liệu kiểm kê, quét cấu hình hệ thống và truy vết phần mềm độc hại. Người quản trị có thể quản lý các module của agent thông qua các thiết lập cấu hình, điều chỉnh giải pháp phù hợp với từng trường hợp sử dụng cụ thể.

Sơ đồ dưới đây sẽ minh họa kiến trúc Agent và các thành phần



Hình 2.4: Các thành phần của Wazuh Agent

Tất các module Agent đều có thể cấu hình được và thực thi nhiều nhiệm vụ bảo mật khác nhau. Cấu trúc dạng Module này cho phép người quản trị có thể bật/tắt mỗi thành phần tùy thuộc vào nhu cầu bảo mật. Sau đây là các module đó:

- **Log collector:** thành phần của agent này cho phép đọc flat log hay còn gọi là raw log(log thô) và các sự kiện an ninh trên Windows, thu thập thông báo của hệ điều hành hay thông báo log của ứng dụng.
- **Command execution:** các Agents sẽ được phép chạy các câu lệnh xác thực định kỳ, thu thập kết quả và báo cáo về Wazuh Server để phục vụ cho việc phân tích sau này. Ngoài ra tùy vào nhu cầu thì người quản trị có thể cấu hình module này vào nhiều trường hợp như là theo dõi thông số của ổ cứng.
- **File integrity monitoring (FIM):** module này giám sát hệ thống file của hệ thống, và báo cáo khi có file được tạo, xóa hay thay đổi. Nó sẽ nắm bắt thông tin về sự thay đổi trong đặc tính của file, quyền thao tác với file, chủ sở hữu, và nội dung của file. Khi mà một trong những sự kiện đó xảy ra, module này sẽ ngay lập tức nắm bắt được ai, cái gì và khi nào chi tiết cụ thể trong thời gian thực. Thêm vào đó module FIM còn xây dựng và duy trì kho dữ liệu với trạng thái của file đang được giám sát, cho phép người dùng có thể truy vấn từ xa từ Wazuh Dashboard.

- Security configuration assessment (SCA): thành phần này luôn đưa ra những đánh giá về cấu hình liên tục, tận dụng cơ chế kiểm tra out-of-the-box dựa trên thang kiểm tra tiêu chuẩn của CIS. Người dùng còn có thể tự tạo SCA riêng để giám sát và siết chặt các chính sách bảo mật (Security Policies).
- System Inventory: agent module này sẽ định kỳ chạy rà quét, thu thập dữ liệu inventory như là phiên bản hệ điều hành, interface mạng, các tiến trình đang chạy, các ứng dụng được cài đặt, và danh sách các port đang mở. Kết quả scan sẽ được lưu trữ trong cơ sở dữ liệu SQLite dưới local có thể truy vấn từ xa.
- Malware detection: sử dụng lõi tiếp cận non-signature-based, thành phần này có khả năng phát hiện các dị thường và sự hiện diện khả thi của rootkits. Bên cạnh đó, module này có khả năng truy vết các tiến trình ẩn, file ẩn, và port ẩn trong lúc giám sát hệ thống.
- Active Response: sẽ tự động hóa một số thao tác khi mà phát hiện được mối đe dọa như là ngắt kết nối đến máy chủ C2, dừng ngay tiến trình bị nghi ngờ hoặc chủ động xóa file độc hại. Ngoài ra ta có thể tự customize được kịch bản của Active Response.
- Container Security Monitoring: module agent này được tích hợp với Docker Engine API để giám sát các thay đổi trong môi trường container. Ví dụ, nó phát hiện các thay đổi đối với container image, cấu hình mạng hoặc data volume. Ngoài ra, nó còn cảnh báo về các container chạy ở chế độ đặc quyền (privileged mode) và về người dùng đang thực thi lệnh trong một container đang chạy.
- Cloud Security Monitoring: thành phần này giám sát các nhà cung cấp dịch vụ đám mây như Amazon Web Services (AWS), Microsoft Azure hoặc Google Cloud Platform (GCP). Nó giao tiếp trực tiếp với API của các nền tảng này. Thành phần này có khả năng phát hiện các thay đổi trong hạ tầng đám mây (ví dụ: tạo người dùng mới, thay đổi nhóm bảo mật, dùng một máy ảo, v.v.) và thu thập dữ liệu log của dịch vụ đám

mây (ví dụ: AWS CloudTrail, AWS Macie, AWS GuardDuty, Azure Active Directory, v.v.).

2.1.4. Một số port phổ biến

Thành phần	Port	Giao thức	Mục đích
Wazuh Server	1514	TCP (Mặc định)	Dịch vụ kết nối Agent
	1514	UDP (Tùy chọn)	Dịch vụ kết nối Agent (Mặc định tắt)
	1515	TCP	Dịch vụ đăng ký Agent
	1516	TCP	Wazuh Cluster Daemon
	514	UDP (Mặc định)	Thu thập Syslog (Mặc định tắt)
	514	TCP (Tùy chọn)	Thu thập Syslog (Mặc định tắt)
	55000	TCP	Wazuh Server Restful API
Wazuh Indexer	9200	TCP	WazuhIndexer Restful API
	9300-9400	TCP	Giao tiếp giữa các WazuhIndexer Cluster
Wazuh Dashboard	443	TCP	Interface người dùng web của Wazuh

Bảng 2: Một số port phổ biến

2.2. Shuffle SOAR

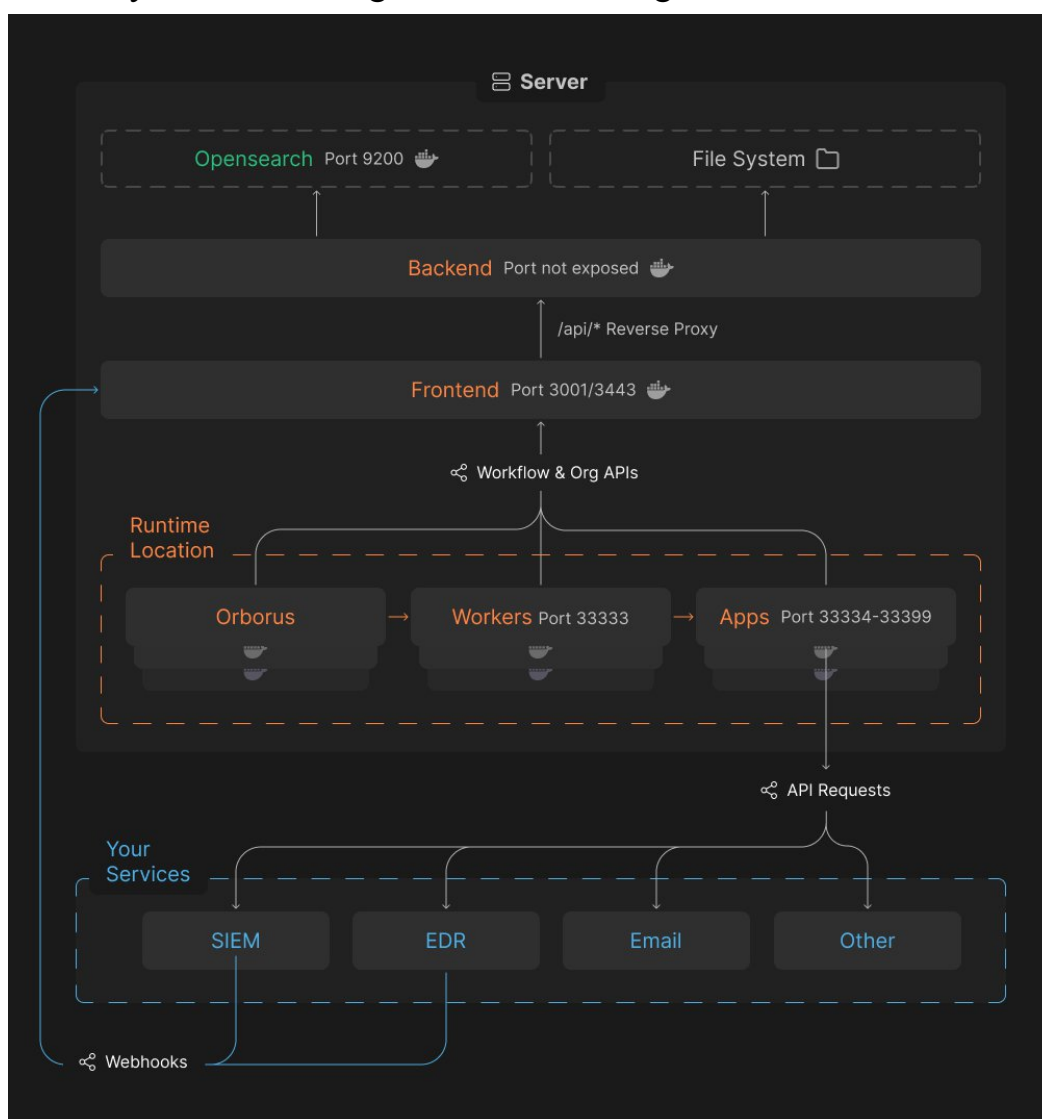
2.2.1. Kiến trúc của Shuffle

Nền tảng của Shuffle được chia làm 2 phần chính: Server và Workers.

- Server đóng vai trò là máy chủ trung tâm, xử lý mọi hoạt động từ API cho đến việc xác thực Workflow.
- Workers là các thành phần độc lập khác, hoạt động theo mô hình tương tự Microservice.

Hai phần (Server và Workers) có thể được cài đặt trên các máy chủ khác nhau và hỗ trợ triển khai theo mô hình cluster.

Dưới đây là flow mà single-server hoạt động:



Hình 2.5: Kiến trúc của Shuffle

Server Layer bao gồm 4 thành phần sau:

OpenSearch (chạy port 9200) và File System: nơi lưu trữ dữ liệu.

FrontEnd và BackEnd:

- FrontEnd đóng vai trò là dashboard nơi người dùng thực hiện thao tác cấu hình workflow.
- BackEnd thực hiện xử lý API.

Runtime Location (Nơi thực thi tác vụ)

- Orborus: thành phần điều phối, chịu trách nhiệm quản lý việc phân bổ công việc cho Workers và Apps.
- Workers (Port 33333): các tiến trình thực thi độc lập, đảm nhiệm việc chạy workflow, gần giống như Microservices.
- App (Port 33334-33399): nơi chứa các ứng dụng/tích hợp (ví dụ: Telegram, VirusTotal, Wazuh, TheHive...). Mỗi app có thể được triển khai như một dịch vụ riêng.

Your Services (dịch vụ bên ngoài tích hợp với Shuffle)

- Bao gồm SIEM, EDR, Email, Other (các hệ thống bên ngoài mà Shuffle giao tiếp).
- Shuffle giao tiếp với các dịch vụ này thông qua:
 - ❖ API Requests (gọi API tới dịch vụ ngoài).
 - ❖ Webhooks (dịch vụ ngoài gửi dữ liệu về Shuffle).

Ta có luồng tổng quát của kiến trúc Shuffle như sau:

Người dùng truy cập vào FrontEnd để tạo workflow => Workflow được lưu trong BackEnd + OpenSearch => Khi có sự kiện, workflow được kích hoạt sẽ chuyển đến Orborus => Orborus phân bổ công việc cho Workers và Apps => Apps sẽ gửi/nhận dữ liệu từ các dịch vụ bên ngoài (SIEM, EDR, Email...) => Kết quả phản hồi quay về hệ thống và hiển thị cho người dùng.

2.2.2. Các framework Shuffle sử dụng

Shuffle được xây dựng dựa trên các framework đã tồn tại và được công nhận rộng rãi, với mục tiêu hỗ trợ cộng đồng an ninh mạng phát triển, thay vì chỉ làm gia tăng sự phức tạp.

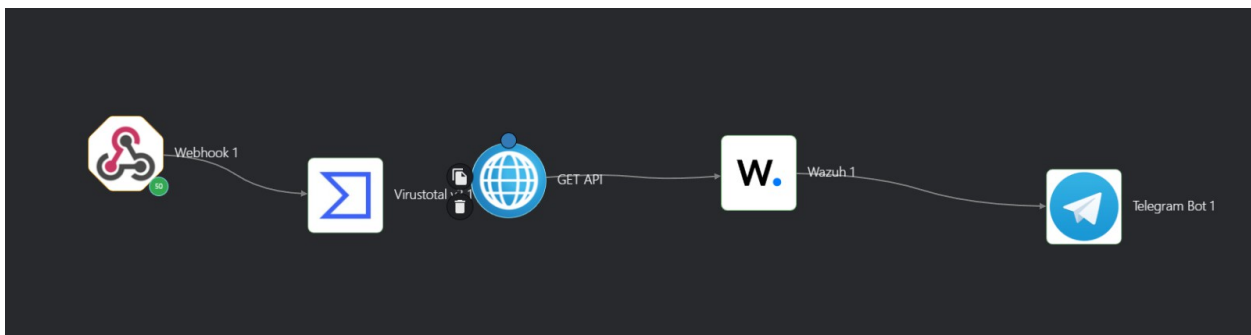
- OpenAPI – Được sử dụng để tải và sinh ra các đặc tả API có thể áp dụng cho nhiều nền tảng khác ngoài Shuffle. Đây là một tiêu chuẩn phổ biến được hầu hết các doanh nghiệp triển khai, tuy nhiên ngành công nghiệp an ninh mạng vẫn còn chậm chân trong việc áp dụng.
- Mitre ATT&CK – Được dùng để xây dựng các workflow phục vụ mục đích tổng quát, giúp quá trình triển khai và sử dụng trở nên thuận tiện hơn. Các phát hiện dựa trên Mitre ATT&CK có mối liên hệ trực tiếp với mức độ rủi ro, đồng thời có thể được dùng như các chỉ số KPI để thuyết phục lãnh đạo đầu tư vào nền tảng.
- CACAO – Là một tiêu chuẩn hóa trong việc xử lý tự động hóa mang tính cộng tác. Shuffle được xây dựng hướng đến cộng đồng người dùng rộng rãi và trong dài hạn sẽ cố gắng tuân thủ chặt chẽ với đặc tả CACAO. Hiện tại tính năng này vẫn đang trong quá trình phát triển (tính đến tháng 10/2022).
- Cytoscape – Một hệ thống thiết kế nhẹ và có khả năng mở rộng, được sử dụng để hiển thị mối quan hệ giữa các node trong giao diện Workflow. Cytoscape cung cấp đầy đủ các thành phần cần thiết để xây dựng nên workflow hoàn chỉnh, phục vụ cho nhiều mục đích khác nhau.

2.2.3. Chức năng chính của Shuffle

- Orchestration: Tích hợp với nhiều công cụ bảo mật, SIEM, IDS/IPS, threat intelligence... vào một nền tảng duy nhất.
- Automation: Tự động hóa các tác vụ lặp đi lặp lại như phân tích log, kiểm tra IP/URL độc hại hay tạo ticket task cho SOC L2 nếu gặp cảnh báo level cao ...
- Response: Cho phép xây dựng kịch bản phản ứng nhanh (playbooks) như khóa tài khoản, chặn IP, gửi cảnh báo cho quản trị viên.

2.2.4. Cơ chế hoạt động của workflow

Để hình dung được cách mà SOAR hoạt động ta sẽ tham khảo hình dưới đây:



Hình 2.6: Ví dụ về 1 workflow của Shuffle

Trong Shuffle, Workflow hình trên được thực thi theo mô hình sau:

2.2.4.1. Kích hoạt(Trigger)

Workflow được kích hoạt khi Wazuh phát hiện một cảnh báo SSH Brute Force=> Gửi alert sang Shuffle webhook

Đây là điểm bắt đầu (start node) của workflow

2.2.4.2. Thực thi chuỗi hành động (Execution Flow)

Sau khi trigger khởi động, Worker của Shuffle sẽ lần lượt chạy các node trong workflow:

VirusTotal app: Worker chạy ứng dụng Virustotal , thực hiện HTTP API call tới VirusTotal, trả kết quả về workflow.

HTTP app(Get-API): Worker vẫn thực hiện request HTTP API nhưng đích ở đây là Wazuh API để nhận JSON Web Token dùng cho xác thực.

Wazuh app: Node này thực hiện gọi API để thực hiện module active response từ xa .

Telegram app: Cuối cùng telegram app được khởi chạy, gửi báo cáo đến quản trị viên giúp nắm bắt thông tin nhanh chóng.

2.2.4.3. Cơ chế của Worker và Orborus

- Orborus: Agent kiểm tra job từ backend, tạo Worker mới cho execution này.
- Worker: điều phối toàn bộ luồng, lần lượt chạy container cho từng node (Virustotal => HTTP => Wazuh => Telegram).

- Nếu một App chưa có Docker image, Worker sẽ tải về từ backend hoặc DockerHub.
- Các kết quả (SUCCESS/FAILURE) của từng node sẽ được gửi về backend, lưu log và hiển thị trên giao diện Shuffle.

2.2.4.4. Ý nghĩa workflow

- Tự động hóa: Cảnh báo từ Wazuh được xử lý tự động, không cần SOC Analyst thao tác tay.
- Liên kết công cụ: Workflow này cho thấy sức mạnh của Shuffle khi tích hợp nhiều công cụ khác nhau:
 Wazuh (SIEM) → phát hiện và phản ứng sự cố
 VirusTotal (Threat Intel) → kiểm chứng dữ liệu.
 Telegram (Notification) → gửi cảnh báo cho Analyst.
- Tối ưu phản ứng sự cố: Giảm thời gian phản hồi, tăng khả năng phân tích nhờ tự động hóa toàn bộ pipeline.

2.3. VirusTotal

VirusTotal là một dịch vụ trực tuyến miễn phí giúp phân tích các tệp tin và URL nhằm phát hiện virus, worm, trojan, và các phần mềm độc hại khác. Dịch vụ này sử dụng hàng chục công cụ AntiVirus và công cụ quét trang web để đưa ra kết quả đáng tin cậy. Một số tính năng nổi bật:

- Lưu trữ lịch sử quét tệp: mọi tệp tin đã từng được quét bởi VirusTotal đều được lưu trữ lại, cho phép người dùng tra cứu thông tin qua giá trị hash.
- Cung cấp API: VirusTotal hỗ trợ giao tiếp qua API REST, cho phép truy xuất dữ liệu phân tích mà không cần phải sử dụng giao diện web. API này có hai loại chính là Public API và Private API (cho phép truy vấn nhiều hơn vì phải trả phí), mỗi loại có quyền truy cập và giới hạn khác nhau đó là Public API chỉ cho phép 600 truy vấn/ngày trong khi Private API là vô tận.

Việc tích hợp VirusTotal vào Wazuh giúp kiểm tra độ an toàn của các tệp được giám sát thông qua chức năng FIM – một thành phần chính của Wazuh. Quy trình hoạt động như sau:

- FIM theo dõi mọi thay đổi trên hệ thống tệp tin như tạo mới, chỉnh sửa hoặc xóa. Mỗi tệp sẽ có Hash tương ứng được lưu trữ.
- Một khi có thay đổi xảy ra, Wazuh sẽ phát cảnh báo tới VirusTotal.
- Hệ thống tự động trích xuất mã hash của tệp từ cảnh báo.
- Một truy vấn HTTP POST sẽ được gửi đến API của VirusTotal để kiểm tra mã hash đó.

VirusTotal trả về phản hồi JSON với thông tin về tệp. Wazuh phân tích phản hồi và tạo ra các cảnh báo. Tất cả các cảnh báo này sẽ được ghi vào tệp `/var/ossec/logs/integrations.log` và `/var/ossec/logs/alerts/alerts.log`

2.4. Telegram

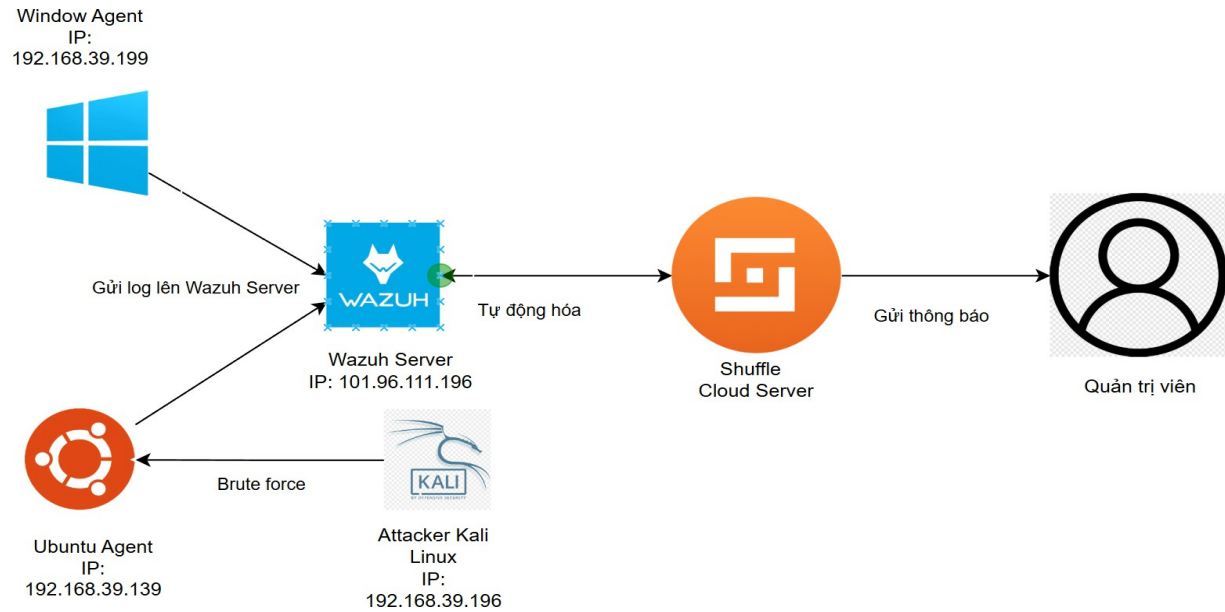
Telegram là một nền tảng nhắn tin phổ biến, hỗ trợ giao tiếp bảo mật, tự động hóa thông qua bot API và rất thích hợp để sử dụng trong môi trường giám sát hệ thống. Khi kết hợp với Wazuh, Telegram có thể trở thành kênh thông báo thời gian thực giúp quản trị viên nhanh chóng nhận được cảnh báo bảo mật.

Cơ chế hoạt động của hệ thống khi tích hợp với Telegram:

- Wazuh Server phát hiện được các sự kiện bất thường và sinh ra cảnh báo.
- Active Response được cấu hình để kích hoạt một script, trong đó:
 - ❖ Trích xuất nội dung cảnh báo từ file JSON hoặc log text.
 - ❖ Gửi thông tin này đến Telegram Bot API để chuyển tiếp vào nhóm/chat đã thiết lập.
- Quản trị viên hoặc người dùng sẽ nhận được cảnh báo trực tiếp trên ứng dụng Telegram.

CHƯƠNG 3 : TRIỂN KHAI THỰC NGHIỆM

3.1. Mô hình thực nghiệm



Hình 3.1: Mô hình triển khai thực nghiệm

Windows Agent:

- IP Address: 192.168.39.199

- Vai trò: Thu thập log trên máy Windows rồi gửi log lên Wazuh Server giám sát.

Ubuntu Agent:

- IP Address: 192.168.39.139

- Vai trò: Thu thập log trên máy Linux rồi gửi log lên Wazuh Server giám sát.

Kali Linux:

- IP Address: 192.168.39.196

- Vai trò: Attacker tấn công SSH Brute Force nạn nhân Ubuntu Agent

Wazuh Server:

- IP Address: 101.96.111.196

-Vai trò: Quản lý tập trung log từ agent, phát hiện và phản ứng các hành vi độc hại của attacker.

Shuffler:

-Dịch vụ SOAR Cloud Server

-Vai trò: Tự động điều phối và phản ứng sự cố nhận alert từ Wazuh, làm giàu thông tin với VirusTotal, rồi thông báo cho quản trị viên qua Telegram.

Quản trị viên:

-Máy host thật Windows 11

-Vai trò: Giám sát trên SIEM, quản lý Playbook Shuffle, nhận thông báo từ hệ thống.

3.2. Triển khai thực nghiệm các Playbook

3.2.1. Phát hiện hành vi sử dụng công cụ Mimikatz



- Lên Wazuh dashboard để chỉnh rule phát hiện sử dụng mimikatz ở file local_rules.xml

- Tag <group> để phân loại nhóm rule trong Wazuh
- <rule> sẽ bao quanh một rule , có tham số như id, level
- <if_group> là điều kiện để rule kích hoạt, ở đây rule phải thuộc group Sysmon_event1 là nhóm các rule Sysmon Event ID 1 khởi tạo tiến trình
- <field> chứa các trường của rule, ở đây win.evtdata.originalFileName chỉ tên gốc của file (dù file có bị đổi tên vẫn kích hoạt rule)
- <description> mô tả rule
- <mitre> mapping với MITRE ATT&CK framework , ở đây T1003 là Credential Dumping(Trích xuất thông tin đăng nhập)

Tạo rule xong restart server để cập nhật rule.

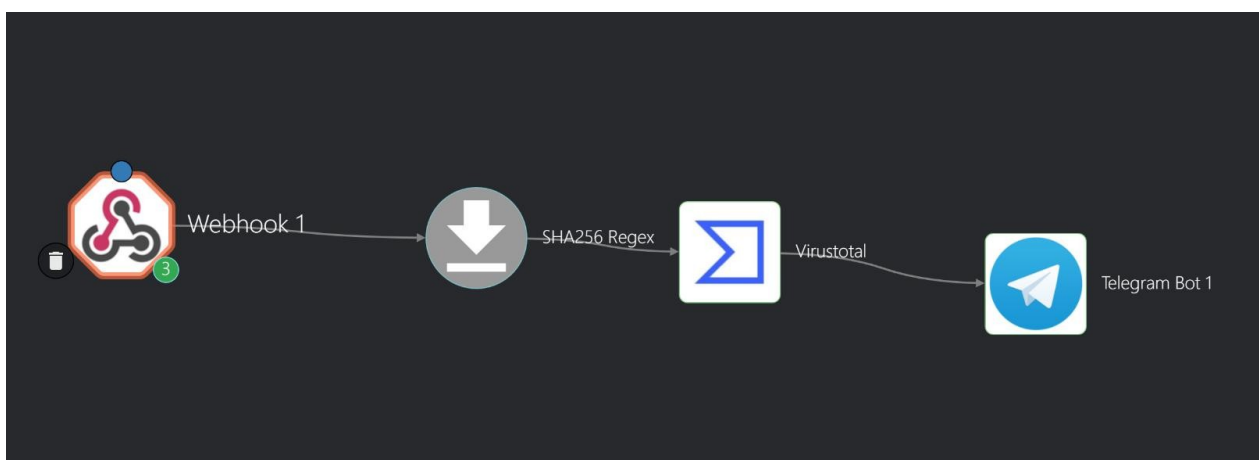
Trên Wazuh server thêm đoạn integration vào file ossec.conf để tích hợp Wazuh với Shuffle

```
<integration>
  <name>shuffle</name>
  <hook_url>https://shuffler.io/api/v1/hooks/webhook_1e64b137-f05c-40db-
b4ba-3fe4e186274b </hook_url>
  <rule_id>100002</rule_id>
  <alert_format>json</alert_format>
</integration>
```

<hook_url> là webhook url của Shuffle khi có alert Wazuh sẽ POST dữ liệu lên URL này

<rule_id> chỉ những rule có rule_id trong tag này mới được gửi lên Shuffle (vẫn còn 1 số tag để kích hoạt nữa như <level>, <group>, ...)

<alert_format> gửi dữ liệu dưới dạng JSON



Hình 3.2: Workflow kịch bản 1

-Trên web Shuffle cấu hình workflow để tự động hóa, đây là workflow của kịch bản này

The screenshot shows the 'Parameters' section of a web interface. It features a red circle icon next to the text 'Webhook URI'. Below this is a text input field containing the URL 'https://shuffler.io/api/v1/hooks/webh'. To the right of the input field is a copy icon. At the bottom of the section are two buttons: a grey 'Start' button and an orange 'Stop' button.

Node webhook ta chỉ cần bật lên để nhận dữ liệu từ Wazuh Server gửi đến

Find Actions
Regex capture group

Input data *

\$exec.text.win.eventdata.hashes

Regex *

SHA256=([0-9A-Fa-f]{64})

Node SHA256_Regex để trích xuất hash dạng sha256 trong alert

Find Actions
Get a hash report

Id *

\$sha256_regex.group_0.#

Node Virustotal ta chỉ cần Action: Get a hash report và nhận hash từ Node SHA256_Regex làm đầu vào. Node này sẽ gửi hash lên trang chủ Virustotal để kiểm tra về danh tiếng của hash này dựa trên các đánh giá từ các Security Vendor uy tín qua đó gửi lại báo cáo cho Node dưới dạng JSON.

Find Actions

Send message

Simple

Advanced

Api token *

8482163049:AAEutYgqj066QCPmGVW

! Message

Alert: \$exec.title

Times: \$exec.timestamp

Agent: \$exec.all_fields.agent.name,

IP:\$exec.all_fields.agent.ip

Security Vendor Malware

Counts:\$virustotal.#.body.data.attri

! Chat id

xxxxxxxxxx

Ở node cuối Telegram ta chọn Action: Send message, điền API token , Chat id , cuối cùng là Message nội dung mà Telegram gửi về cho quản trị viên.

« Downloads > mimikatz-master > mimikatz-master > x64			
Search x64			
Name	Date modified	Type	
filetest	12/17/2025 2:54 AM	Application	
mimidrv.sys	12/17/2025 2:54 AM	System file	
mimilib.dll	12/17/2025 2:54 AM	Application extension	

- Trên máy Windows ta sửa tên file mimikatz.exe thành filetest.exe

```
PS C:\Users\Administrator.WIN-42D6PSDN7VP\Downloads\mimikatz-master\mimikatz-master\x64> ls

Directory: C:\Users\Administrator.WIN-42D6PSDN7VP\Downloads\mimikatz-master\mimikatz-master\x64

Mode                LastWriteTime         Length Name
----                -
-a----           12/17/2025   2:54 AM         1250056 filetest.exe
-a----           12/17/2025   2:54 AM          36696 mimidrv.sys
-a----           12/17/2025   2:54 AM          46856 mimilib.dll

PS C:\Users\Administrator.WIN-42D6PSDN7VP\Downloads\mimikatz-master\mimikatz-master\x64> .\filetest.exe

.#####.  mimikatz 2.2.0 (x64) #18362 Feb 29 2020 11:13:36
## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## < > ## /*** Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##  > http://blog.gentilkiwi.com/mimikatz
## v ##   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'  > http://pingcastle.com / http://mysmartlogon.com   ***/

mimikatz #
```

Thực thi filetest.exe trên máy Windows để kích hoạt workflow tự động



Workflow đã chạy thành công, trên máy Quản trị viên đã thấy được cảnh báo gửi về trên Telegram

3.2.2. Phát hiện file mã độc và tự động gỡ bỏ

Cũng giống như kịch bản trước trên Wazuh Server thêm cấu hình integration vào file ossec.conf

```
<integration>
  <name>shuffle</name>
```



```
<hook_url>https://shuffler.io/api/v1/hooks/webhook_1fc1fc27-7ace-5b79-  
b7f7-915d99a6a5d3 </hook_url>  
<rule_id>550,554</rule_id>  
<alert_format>json</alert_format>  
</integration>
```

Ở kịch bản này ta sẽ gửi các rule có rule_id là 550, 554 để phát hiện khi có 1 rule được thêm vào hệ thống hoặc có thể bị attacker sửa đổi thành file mã độc nó sẽ kích hoạt rule tạo cảnh báo

```
<rule id="550" level="7">  
  <category>ossec</category>  
  <decoded_as>syscheck_integrity_changed</decoded_as>  
  <description>Integrity checksum changed.</description>  
  <mitre>  
    <id>T1565.001</id>  
  </mitre>  
  <group>syscheck, syscheck_entry_modified, syscheck_file, pci_dss_11.5,  
    .4, tsc_PI1.5, tsc_CC6.1, tsc_CC6.8, tsc_CC7.2, tsc_CC7.3, </group>  
</rule>
```

Rule 550 là rule phát hiện khi một file có sự thay đổi về các thuộc tính như hash, permission,...

```
<rule id="554" level="5">  
  <category>ossec</category>  
  <decoded_as>syscheck_new_entry</decoded_as>  
  <description>File added to the system.</description>  
  <group>syscheck, syscheck_entry_added, syscheck_file, pci_dss_11.5,  
    , tsc_PI1.5, tsc_CC6.1, tsc_CC6.8, tsc_CC7.2, tsc_CC7.3, </group>  
</rule>
```

Rule 554 là rule phát hiện khi một file được thêm vào trong hệ thống

Tiếp theo trong file ossec.conf tiếp tục thêm tag command

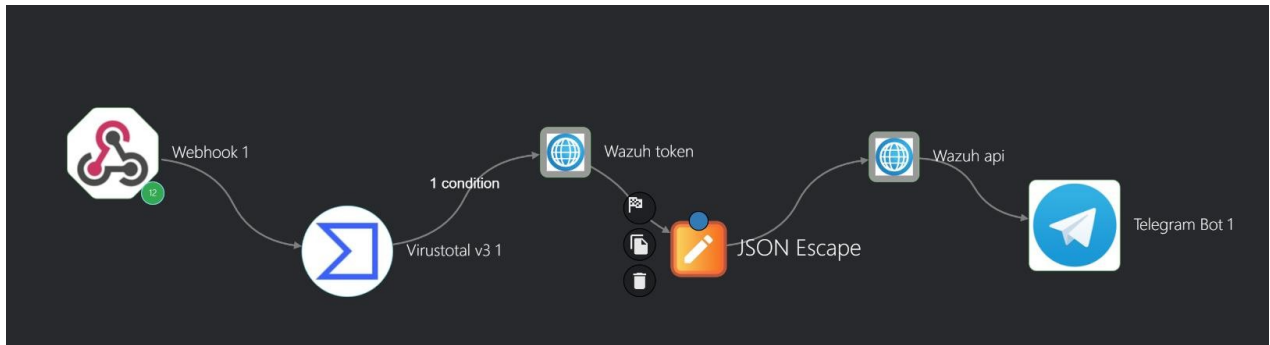
```
<command>  
  <name>shuffler-windows-cmd</name>  
  <executable>exec-shuffler.cmd</executable>
```



```
<timeout_allowed>no</timeout_allowed>  
</command>
```

Tag command này dùng để khai báo lệnh active response mà wazuh agent sẽ thực thi khi có sự kiện thích hợp

<executable> là script hoặc file có thể thực thi mà wazuh agent sẽ thực thi khi nhận lệnh từ wazuh server



Hình 3.3: Workflow kịch bản 2

-Tiếp theo trên web Shuffle cấu hình workflow để tự động hóa

Cũng giống như kịch bản trước node webhook sẽ cần được bật để nhận alert từ Wazuh Server gửi đến, tiếp theo node VirusTotal sẽ lấy hash của alert và gửi lên trang chủ thông qua API để lấy thông tin report .

The screenshot shows the 'Condition' configuration interface. It has two main sections: 'source' and 'destination'. The 'source' section has a dropdown menu with '\$virustotal_v3_1.body.data' selected. The 'destination' section has a dropdown menu with '10' selected. Between these two sections is a comparison operator dropdown menu with 'larger than' selected. At the bottom, there are 'Cancel' and 'Submit' buttons. A note at the bottom left says: 'PS: Conditions can't be used for loops [.#]. Use the filters list action. Learn more'.

Ở đây nối giữa Node VirusTotal và Node WazuhToken ta thêm 1 điều kiện nếu `$virustotal_v3_1.body.data.attributes.last_analysis_stats.malicious > 10` thì sẽ

chạy tiếp workflow còn không nó sẽ dừng. Ở đây tham số này chỉ ra số security vendor đánh giá file này là độc hại.

The image shows a configuration interface for a REST client. It has a dark theme. At the top, there is a 'Find Actions' search bar with 'GET' selected. Below this is the 'Url' field, which is marked with an asterisk and contains the text 'https://101.96.111.196:55000/security'. The 'Headers' section contains one header: 'Content-Type: application/json'. The 'Username' field contains 'wazuh-wui'. The 'Password' field is masked with dots. Each field has a plus icon to its right, and the 'Url', 'Headers', 'Username', and 'Password' sections have expand/collapse arrows in the top right corner.

Node Wazuh_Token sẽ có vai trò lấy JSON Web Token của Wazuh Server để phục vụ mục đích xác thực. Ở đây Node này sẽ gửi gói tin GET đến url: <https://101.96.111.196:55000/security/user/authenticate?raw=true> với username, password được nhập để xác thực.

Find Actions
Replace value ▼

Input data * ↗

\$exec.all_fields.syscheck.path ⊕

Translate from * ↗

\ ⊕

Translate to * ↗

\\ ⊕

Node JSON Escape có vai trò thêm các dấu \ để escape ký tự đặc biệt để khi gửi JSON data cấu trúc sẽ không bị lỗi , ở đây nó escape đường dẫn của file mã độc bằng cách thêm \ vào trước ký tự \ (đường dẫn window thường dùng \).

The image shows a REST client interface with a dark theme. At the top, there is a 'Find Actions' search bar containing the text 'PUT'. Below this, the 'Url' field is marked with a red asterisk and contains the URL 'https://101.96.111.196:55000/active-r'. The 'Body' field is also marked with a red asterisk and contains a JSON object: {"command": "shuffler-windows-cmd0", "arguments": ["Remove-Item -Path '\$json_escape' -Force"]}. The 'Headers' section contains three entries: 'Content-Type: application/json', 'Authorization: Bearer', and '\$wazuh_token.body'. Each field has a plus icon in a circle to its right, indicating it can be expanded or edited.

Find Actions

PUT

Url *

https://101.96.111.196:55000/active-r

Body *

```
{  
  "command": "shuffler-windows-cmd0",  
  "arguments": ["Remove-Item -Path '$json_escape' -Force"]  
}
```

Headers

Content-Type: application/json
Authorization: Bearer
\$wazuh_token.body

Node Wazuh_API có vai trò quan trọng nhất vì nó gửi gói PUT đến url [https://101.96.111.196:55000/active-response?agents_list=\\$exec.all_fields.agent.id](https://101.96.111.196:55000/active-response?agents_list=$exec.all_fields.agent.id) (ở đây \$exec.all_fields.agent.id là biến agent id, chỉ định id agent chạy lệnh) url này là API gửi lệnh active response cho agent có id theo tham số agents_lists

Phần body chứa tham số command chỉ định lệnh gửi xuống cho agent và tham số argument là xóa file với path được lấy từ node JSON_Escape. Ở phần Headers sẽ có dòng Authorization: Bearer \$wazuh_token.body (đây là JSON Web Token được lấy trong Node Wazuh_Token)

The image shows a configuration interface for a 'Send message' action. At the top, there is a search bar labeled 'Find Actions' with 'Send message' selected. Below this are two tabs: 'Simple' (active) and 'Advanced'. The 'Api token' field is highlighted with a red border and contains the value '8482163049:AAEutYgqj066QCPmGVM'. Below it is a 'Message' field, also highlighted with a red border, containing the text: 'File \$json_escape deleted successful !', 'Times:\$exec.timestamp', 'Agent: \$exec.all_fields.agent.name,', 'IP: \$exec.all_fields.agent.ip', and 'Security Vendors Malware Counts:'. At the bottom is a 'Chat id' field, highlighted with a red border, containing the value 'xxxxxxxxxx'. Each field has a plus icon to its right.

Cuối cùng là Node Telegram với message có tham số File path, Time, Agent name, Agent IP, số lượng Security Vendors xem file này là độc hại sẽ được gửi cho Quản trị viên.

- Trên Windows Agent tạo file exec-shuffler.cmd trên đường dẫn C:\Program Files (x86)\ossec-agent\active-response\bin (đây là nơi chứa các file thực thi active response trên máy agent)

```
@echo off
setlocal enabledelayedexpansion
set /p INPUT=
for /f "tokens=2 delims=[]" %%a in ("!INPUT!") do
    ( set RAW_CMD=%%a
      set FINAL_CMD=!RAW_CMD:"=!
    )
    if not "!FINAL_CMD!"==" (
        powershell.exe -ExecutionPolicy Bypass -Command "!FINAL_CMD!" >>
"C:\Program Files (x86)\ossec-agent\active-response\active-responses.log" 2>&1
    )
```

Đây là script cho phép Wazuh Agent thực thi lệnh PowerShell được Wazuh Server gửi xuống thông qua Active Response, với quyền thực thi cao và bỏ qua PowerShell Execution Policy

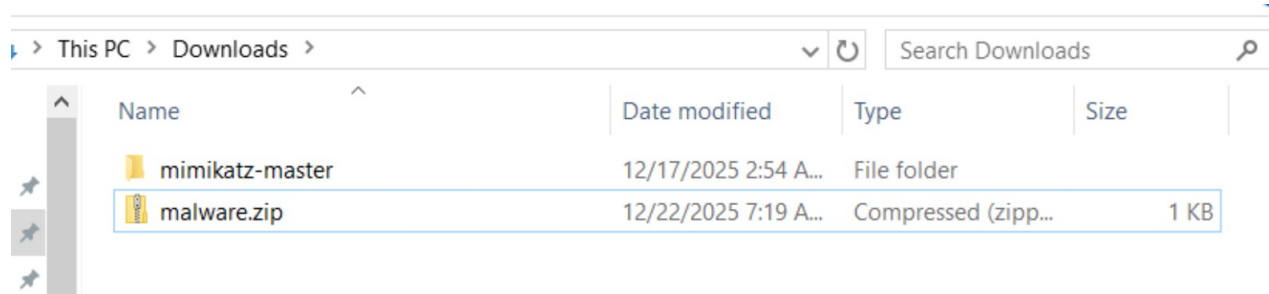
Tiếp tục trên máy Windows Agent ta vào thư mục C:\Program Files (x86)\ossec-agent chỉnh sửa file ossec.conf

Ta tìm đến tag <syscheck></syscheck> đặt tag <directories> vào trong

```
<directories realtime="yes" report_changes="yes">C:\Users\Administrator
\Downloads</directories>
```

Ở đây tag syscheck cho phép wazuh agent theo dõi và giám sát sự thay đổi file trong thư mục được đặt trong <syscheck>

<directories> chính là thư mục được wazuh agent giám sát, ở đây ta theo dõi thư mục Downloads của user Administrator.



Tiếp theo đến giai đoạn thực hiện workflow, ta tạo sẵn 1 file mã độc tên malware.txt rồi nén nó vào thư mục malware.zip đặt trong thư mục Downloads . Khi người dùng giải nén file mã độc ra , wazuh agent được cấu hình theo dõi thư mục sẽ gửi thông tin file thay đổi lên Wazuh Server , trên Server nhận log kích hoạt rule_id 554 rồi tạo alert gửi cho Shuffle để bắt đầu workflow như ta đã tạo ở trên. Khi chạy xong workflow file được giải nén sẽ bị xóa và trên Telegram máy Quản trị viên sẽ có thông báo gửi về.

```
File c:  
\\users\\administrator.win-42d6psdn7vp\\downloads\\malware.txt.txt  
deleted successful !  
Times:2025-12-22T08:58:39.014+0000  
Agent: WINSV, IP: 192.168.39.199  
Security Vendors Malware Counts: 62  
3:58 PM
```

3.2.3. Phát hiện tấn công ssh brute force và tự động block

Trên máy Wazuh Server thêm tag integration như 2 kịch bản trước

```
<integration>  
  <name>shuffle</name>  
  <hook_url>https://shuffler.io/api/v1/hooks/webhook_e9dec404-a6a6-4d32-a9fb-7f855e5ca304</hook_url>  
  <rule_id>5763</rule_id>  
  <alert_format>json</alert_format>  
</integration>
```

Tag này gửi alert lên cho webhook Shuffle khi rule_id 5763 kích hoạt.

```
<rule id="5763" level="10" frequency="8" timeframe="120" ignore="60">
  <if_matched_sid>5760</if_matched_sid>
  <same_source_ip/>
  <description>sshd: brute force trying to get access to the system. Authentication failed.</description>
  <mitre>
    <id>T1110</id>
  </mitre>
  <group>authentication_failures,gdpr_IV_35.7.d,gdpr_IV_32.2,hipaa_164.312.b,nist_800_53_SI.4,nist_800_53_
    .4,pci_dss_10.2.5,tsc_CC6.1,tsc_CC6.8,tsc_CC7.2,tsc_CC7.3,</group>
</rule>
```

Rule_id 5763 kích hoạt khi nguồn từ cùng 1 IP đăng nhập thất bại 8 lần trong khoảng thời gian 120 giây . Rule này còn được correlation từ nhiều rule khác.

```
<rule id="5700" level="0" noalert="1">
  <decoded_as>sshd</decoded_as>
  <description>SSHD messages grouped.</description>
</rule>
```

Rule này xác định đây là log của nhóm SSH

```
<rule id="5716" level="5">
  <if_sid>5700</if_sid>
  <match>^Failed|^error: PAM: Authentication</match>
  <description>sshd: authentication failed.</description>
  <mitre>
    <id>T1110</id>
  </mitre>
  <group>authentication_failed,gdpr_IV_35.7.d,gdpr_IV_32.2
    ,tsc_CC6.1,tsc_CC6.8,tsc_CC7.2,tsc_CC7.3,</group>
</rule>
```

Rule này phát hiện đăng nhập thất bại dịch vụ SSH


```

<rule id="5760" level="5">
  <if_sid>5700,5716</if_sid>
  <match>Failed password|Failed keyboard|authentication error</match>
  <description>sshd: authentication failed.</description>
  <mitre>
    <id>T1110.001</id>
    <id>T1021.004</id>
  </mitre>
  <group>authentication_failed,gdpr_IV_35.7.d,gdpr_IV_32.2,gpg13_7.1,
    ,tsc_CC6.1,tsc_CC6.8,tsc_CC7.2,tsc_CC7.3,</group>
</rule>

```

Rule này phát hiện cụ thể hơn các kiểu đăng nhập SSH thất bại

Từ các rule trên ta thấy rule 5763 được correlation từ rất nhiều rule nên độ chính xác của rule được đánh giá cao nên ta sẽ gửi alert được kích hoạt bởi rule này cho Shuffle tự động hóa block hành vi brute force

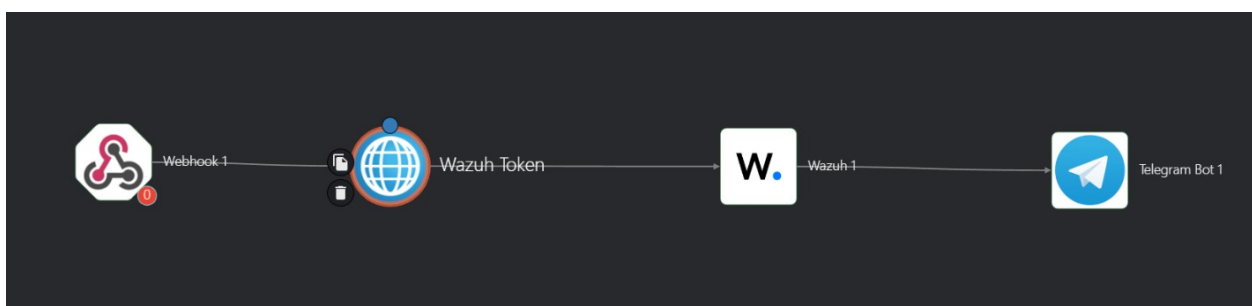
Để tiến hành block IP của attacker ta sẽ dùng đến active response command firewall-drop của Wazuh, đây là command có sẵn trên Wazuh Server và script có sẵn trên Agent nên ta sẽ không phải thêm vào

```

<command>
  <name>firewall-drop</name>
  <executable>firewall-drop</executable>
  <timeout_allowed>yes</timeout_allowed>
</command>

```

Script firewall-drop có sẵn trên Ubuntu Agent trong thư mục /var/ossec/active-response/bin. Ta sẽ dùng API để gọi active response đây từ Wazuh Server xuống Agent thực thi script firewall-drop block IP của attacker.



Hình 3.4:Workflow kịch bản 3

- Trên Web Shuffle ta cấu hình workflow để tự động phản ứng sự cố
- Node Webhook vẫn như 2 kịch bản trước chỉ cần bật Start để nhận alert từ Wazuh Server. Node Wazuh_Token có vai trò lấy JSON Web Token để dùng xác thực .

Wazuh_1
0

+ Authenticate Wazuh

Find Actions
Run command

Apikey *
.....

Url *
https://101.96.111.196:55000

Simple Advanced

! Custom
Value

! Command
firewall-drop300

! Alert
{"data": {"srcip": "\$exec.all_fields.data.srcip"}}

Headers
Content-Type=application/json
Accept=application/json

Queries
view=basic&redirect=test

Ssl verify
False

To file
False

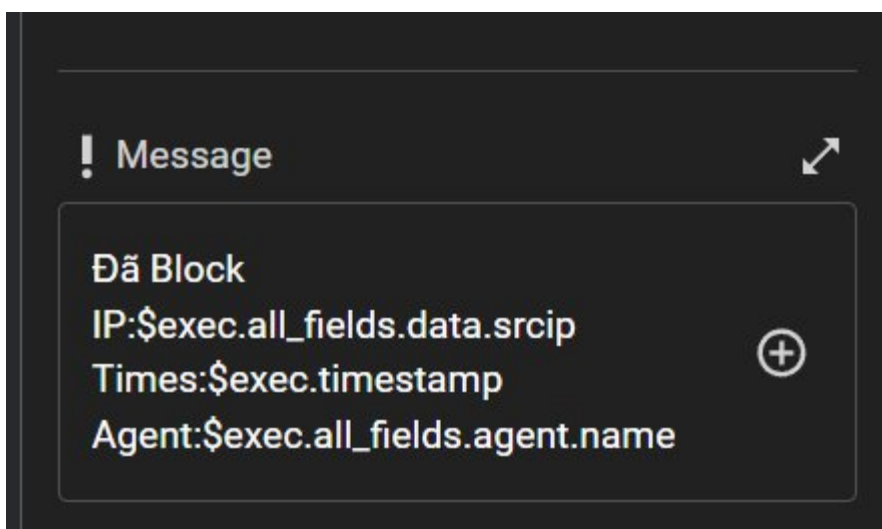
Agents list
\$exec.all_fields.agent.id

Pretty
Value

Wait for complete
true

Node Wazuh ở đây có vai trò gửi lệnh xuống Agent thông qua API.

Trường API key lấy từ node Wazuh_Token, trường command là firewall-drop300(ở đây 300 là thời gian block IP, API quy định command được gọi phải là firewall kèm theo thời gian timeout). Trường Alert chứa thông tin IP sẽ bị block , cuối cùng là Agents list là thông tin id của agent.



Node telegram cuối cùng sẽ có nhiệm vụ gửi thông tin đã block ip cho quản trị viên kèm theo các thông tin thêm.

- Tiếp theo đến giai đoạn thực thi workflow

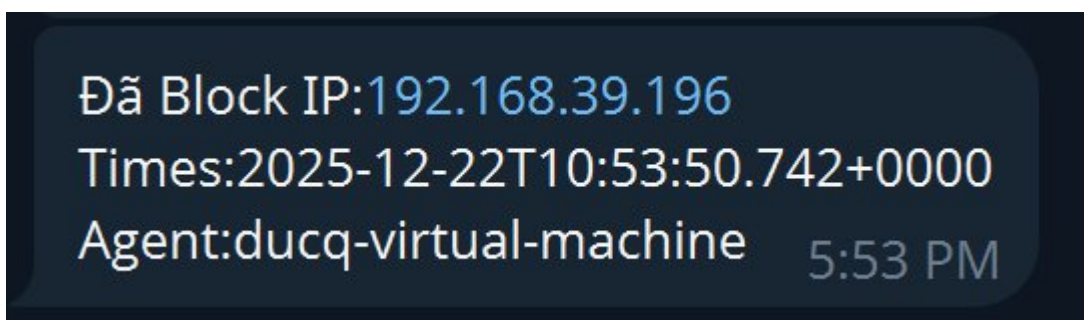
```
(root@kali)-[/usr/share/wordlists]
# ping 192.168.39.139
PING 192.168.39.139 (192.168.39.139) 56(84) bytes of data.
64 bytes from 192.168.39.139: icmp_seq=1 ttl=64 time=1.62 ms
64 bytes from 192.168.39.139: icmp_seq=2 ttl=64 time=0.661 ms
64 bytes from 192.168.39.139: icmp_seq=3 ttl=64 time=0.903 ms
```

Trên máy attacker kết nối thử đến máy nạn nhân đã thành công

```
hydra -l root -P /usr/share/wordlists/rockyou.txt ssh://192.168.39.139 -t 4 -I
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is no
n-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-22 05:53:43
[WARNING] Restorefile (ignored ...) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://192.168.39.139:22/
```

Dùng tool hydra để brute force nạn nhân



Trên máy quản trị viên xuất hiện thông báo Telegram đã block IP attacker

```
(root@kali)-[/usr/share/wordlists]
# ping 192.168.39.139
PING 192.168.39.139 (192.168.39.139) 56(84) bytes of data.
```

Trên máy Attacker ping lại nạn nhân nhưng không được do đã bị chặn

3.3. Kết luận và đánh giá

Qua quá trình nghiên cứu và thực hiện báo cáo “NGHIÊN CỨU XÂY DỰNG HỆ THỐNG TỰ ĐỘNG PHẢN ỨNG SỰ CỐ DỰA TRÊN SOAR MÃ NGUỒN MỞ”, đề tài đã hoàn thành các mục tiêu đề ra, xây dựng thành công một mô hình SOC thu nhỏ đáp ứng nhu cầu giám sát an ninh mạng thực tế của doanh nghiệp quy mô vừa và nhỏ

Về mặt kiến trúc, hệ thống đã triển khai mô hình SIEM – SOAR dựa trên các giải pháp mã nguồn mở Wazuh và Shuffle, cho phép thu thập log tập trung từ nhiều nguồn, phân tích và tương quan sự kiện, đồng thời hỗ trợ tự động hóa quy trình xử lý sự cố. Kiến trúc này giúp tối ưu chi phí triển khai nhưng vẫn đảm bảo khả năng mở rộng và đáp ứng yêu cầu vận hành trong môi trường doanh nghiệp.

Về mặt kỹ thuật và khả năng vận hành, hệ thống đã được cài đặt, cấu hình và kiểm thử trên môi trường mô phỏng SOC, đảm bảo khả năng giám sát liên tục, phát hiện sớm và cảnh báo kịp thời các hành vi bất thường, hướng tới mục tiêu nâng cao độ sẵn sàng và giảm thời gian phản ứng sự cố.

Quan trọng nhất, về khía cạnh an toàn thông tin, hệ thống đã hiện thực hóa mô hình phòng thủ nhiều lớp thông qua:

- Lớp giám sát host và hệ thống: phát hiện xâm nhập, thay đổi trái phép và hành vi bất thường nhờ Wazuh Agent
- Lớp phân tích và tương quan sự kiện: tổng hợp log, áp dụng rule và threat intelligence để nâng cao độ chính xác cảnh báo.
- Lớp phản ứng và tự động hóa: sử dụng Shuffle SOAR để xây dựng luồng xử lý sự cố từ phát hiện, làm giàu thông tin đến hỗ trợ phản ứng chủ động.

Kết quả kiểm thử thông qua các kịch bản tấn công mô phỏng như brute-force, phát hiện sử dụng tool đáng nghi ngờ, phát hiện thêm và sửa đổi file thành mã độc cho thấy hệ thống hoạt động ổn định, phát hiện và cảnh báo chính xác các hành vi nguy hiểm. Báo cáo không chỉ mang tính lý thuyết mà còn đề xuất một mô hình triển khai khả thi, có tính ứng dụng cao, giúp các doanh nghiệp vừa và nhỏ từng bước nâng cao năng lực giám sát và ứng phó an ninh mạng trong bối cảnh chuyển đổi số hiện nay.

PHỤ LỤC

A. CÀI ĐẶT WAZUH SERVER

Đăng nhập vào máy và cài đặt theo câu lệnh sau:

```
curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh
```

```
curl -sO https://packages.wazuh.com/4.14/config.yml
```

```
wazuh@wazuh:~$ curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh
wazuh@wazuh:~$ curl -sO https://packages.wazuh.com/4.14/config.yml
wazuh@wazuh:~$ ls -lia
total 236
3932162 drwxr-xr-x 4 wazuh wazuh 4096 Dec 19 01:56 .
3932161 drwxr-xr-x 3 root root 4096 Sep 23 07:19 ..
3932170 -rw----- 1 wazuh wazuh 13 Dec 19 01:48 .bash_history
3932163 -rw-r--r-- 1 wazuh wazuh 220 Feb 25 2020 .bash_logout
3932164 -rw-r--r-- 1 wazuh wazuh 3771 Feb 25 2020 .bashrc
3932168 drwx----- 2 wazuh wazuh 4096 Sep 23 07:27 .cache
3932173 -rw-rw-r-- 1 wazuh wazuh 636 Dec 19 01:56 config.yml
3932165 -rw-r--r-- 1 wazuh wazuh 807 Feb 25 2020 .profile
3932166 drwx----- 2 wazuh wazuh 4096 Sep 23 07:19 .ssh
3932172 -rw-rw-r-- 1 wazuh wazuh 199349 Dec 19 01:56 wazuh-install.sh
3932171 -rw----- 1 wazuh wazuh 51 Sep 23 07:27 .Xauthority
wazuh@wazuh:~$
```

Ta sẽ dùng lệnh vi hoặc nano và điền thông tin vào file cấu hình config.yml vì ta đang triển khai theo mô hình single-node nên ta sẽ trở IP của cùng một Server vì Server đó sẽ đảm nhiệm 3 chức năng index, dashboard, manager trong trường hợp IP của Server là 101.96.111.196

```
wazuh@wazuh:~$ cat config.yml
nodes:
  # Wazuh indexer nodes
  indexer:
    - name: tqc-indexernode1
      ip: "101.96.111.196"
    #- name: node-2
    # ip: "<indexer-node-ip>"
    #- name: node-3
    # ip: "<indexer-node-ip>"

  # Wazuh server nodes
  # If there is more than one Wazuh server
  # node, each one must have a node_type
  server:
    - name: tqc-managernode1
      ip: "101.96.111.196"
      node_type: master
    #- name: wazuh-2
    # ip: "<wazuh-manager-ip>"
    # node_type: worker
    #- name: wazuh-3
    # ip: "<wazuh-manager-ip>"
    # node_type: worker

  # Wazuh dashboard nodes
  dashboard:
    - name: tqc-dashboardnode1
      ip: "101.96.111.196"
wazuh@wazuh:~$
```

Vì ip đang sử dụng là ip public, theo cơ chế an toàn của wazuh thì các ip dùng để quản trị cần phải để private, do vậy ta vào file wazuh-install.sh để loại bỏ điều kiện sử dụng ip private


```

wazuh@wazuh: ~
GNU nano 4.8 wazuh-install.sh Modified
exit 1
fi
eval "$(cert_convertCRLFtoLF "${config_file}")"

eval "indexer_node_names=( $(cert_parseYaml "${config_file}" | grep -E "nodes[_]+indexer[_]+[0-9]+=" | cut -d = -f 2 )" )"
eval "server_node_names=( $(cert_parseYaml "${config_file}" | grep -E "nodes[_]+server[_]+[0-9]+=" | cut -d = -f 2 )" )"
eval "dashboard_node_names=( $(cert_parseYaml "${config_file}" | grep -E "nodes[_]+dashboard[_]+[0-9]+=" | cut -d = -f 2 )" )"
eval "indexer_node_ips=( $(cert_parseYaml "${config_file}" | grep -E "nodes[_]+indexer[_]+[0-9]+[_]+ip=" | cut -d = -f 2 )" )"
eval "server_node_ips=( $(cert_parseYaml "${config_file}" | grep -E "nodes[_]+server[_]+[0-9]+[_]+ip=" | cut -d = -f 2 )" )"
eval "dashboard_node_ips=( $(cert_parseYaml "${config_file}" | grep -E "nodes[_]+dashboard[_]+[0-9]+[_]+ip=" | cut -d = -f 2 )" )"
eval "server_node_types=( $(cert_parseYaml "${config_file}" | grep -E "nodes[_]+server[_]+[0-9]+[_]+node_type=" | cut -d = -f 2 )" )"
eval "number_server_ips=( $(cert_parseYaml "${config_file}" | grep -o -E 'nodes[_]+server[_]+[0-9]+[_]+ip' | sort -u | wc -l )" )"
all_ips=$(echo "${indexer_node_ips[@]}" "${server_node_ips[@]}" "${dashboard_node_ips[@]}")

#
for ip in "${all_ips[@]"; do
#
isIP=$(echo "$ip" | grep -P "^[0-9]{1,3}\.[0-9]{1,3}\.[0-9]{1,3}\.[0-9]{1,3}$")
#
if [[ -n "$isIP" ]]; then
#
if ! cert_checkPrivateIp "$ip"; then
#
common_logger -e "The IP $ip is public."
#
exit 1
#
fi
#
done

for i in $(seq 1 "${number_server_ips}"); do
nodes_server="nodes[_]+server[_]+${i}[_]+ip"
eval "server_node_ip_${i}=( $(cert_parseYaml "${config_file}" | grep -E "${nodes_server}" | sed '/\./!d' | cut -d = -f 2 )" )"
done

unique_names=$(echo "${indexer_node_names[@]}" | tr ' ' '\n' | sort -u | tr '\n' ' ')
if [ "${#unique_names[@]}" -ne "${#indexer_node_names[@]}" ]; then
common_logger -e "Duplicated indexer node names."
exit 1
fi

unique_ips=$(echo "${indexer_node_ips[@]}" | tr ' ' '\n' | sort -u | tr '\n' ' ')

```

Sau khi điền xong ta sẽ sử dụng câu lệnh sau để tiến hành sinh file nén của 3 thành phần index, dashboard, manager:

`bash wazuh-install.sh --generate-config-files`

Lúc này sẽ cho ra `wazuh-install-files.tar`, file này ta sẽ giải nén sau

Sau đó ta sẽ chạy bash với câu lệnh dưới để thiết lập thành phần indexer, lưu ý vì trong file `config.yml` ta để name của indexer là `tqc-indexernode1` nên ta sẽ phải để tên dưới câu lệnh giống y hệt do ta đã định nghĩa tên trong file `config.yml` là như vậy nếu điền sai tên trong câu lệnh sẽ báo lỗi:

`bash wazuh-install.sh --wazuh-indexer tqc-indexernode1`

Sau đó ta giải nén `wazuh-install-files.tar` bằng câu lệnh sau:

`tar -axf wazuh-install-files.tar`

Sau khi giải nén ta được thư mục `wazuh-install-files` như hình dưới và quan trọng nhất là file `wazuh-passwords.txt` mọi thông tin đăng nhập sẽ ở trong này:

```

root@wazuh:/home/wazuh# tar -axf wazuh-install-files.tar
root@wazuh:/home/wazuh# ls
wazuh-install-files  wazuh-install-files.tar  wazuh-install.sh
root@wazuh:/home/wazuh# cd wazuh-install-files
root@wazuh:/home/wazuh/wazuh-install-files# ls
admin-key.pem  root-ca.key  tqc-dashboardnode1.pem  tqc-managernode1-key.pem
admin.pem      root-ca.pem  tqc-indexernode1-key.pem  tqc-managernode1.pem
config.yml     tqc-dashboardnode1-key.pem  tqc-indexernode1.pem  wazuh-passwords.txt
root@wazuh:/home/wazuh/wazuh-install-files#

```


Rồi ta sẽ tiến hành khởi động cluster bằng câu lệnh:

```
bash wazuh-install.sh --start-cluster
```

Để kiểm tra xem indexer đã cài đặt đúng chưa sẽ lấy thông tin đăng nhập admin Dashboard ở mục đầu tiên indexer_username như hình dưới:

```
root@wazuh:/home/wazuh/wazuh-install-files# cat wazuh-passwords.txt
# Admin user for the web user interface and Wazuh indexer. Use this user to log in to Wazuh dashboard
indexer_username: 'admin'
indexer_password: 'XXXXXXXXXXXXXXXXXXXX'

# Anomaly detection user for the web user interface
indexer_username: 'anomalyadmin'
indexer_password: 'XXXXXXXXXXXXXXXXXXXX'

# Wazuh dashboard user for establishing the connection with Wazuh indexer
indexer_username: 'kibanaserver'
indexer_password: 'XXXXXXXXXXXXXXXXXXXX'

# Regular Dashboard user, only has read permissions to all indices and all permissions on the .kibana index
indexer_username: 'kibanaro'
indexer_password: 'XXXXXXXXXXXXXXXXXXXX'

# Filebeat user for CRUD operations on Wazuh indices
indexer_username: 'logstash'
indexer_password: 'XXXXXXXXXXXXXXXXXXXX'

# User with READ access to all indices
indexer_username: 'readall'
indexer_password: 'XXXXXXXXXXXXXXXXXXXX'

# User with permissions to perform snapshot and restore operations
indexer_username: 'snapshotrestore'
indexer_password: 'XXXXXXXXXXXXXXXXXXXX'

# Password for wazuh API user
api_username: 'wazuh'
api_password: 'XXXXXXXXXXXXXXXXXXXX'

# Password for wazuh-wui API user
api_username: 'wazuh-wui'
api_password: 'XXXXXXXXXXXXXXXXXXXX'

root@wazuh:/home/wazuh/wazuh-install-files#
```

Rồi ta chạy lệnh curl để kiểm tra xem indexer đã lên chưa:

```
curl -k -u admin:<ADMIN_PASSWORD> https://101.96.111.196:9200
```

Và đây là kết quả đạt được nếu ta nhận thông báo như này tức là indexer đã deploy thành công:

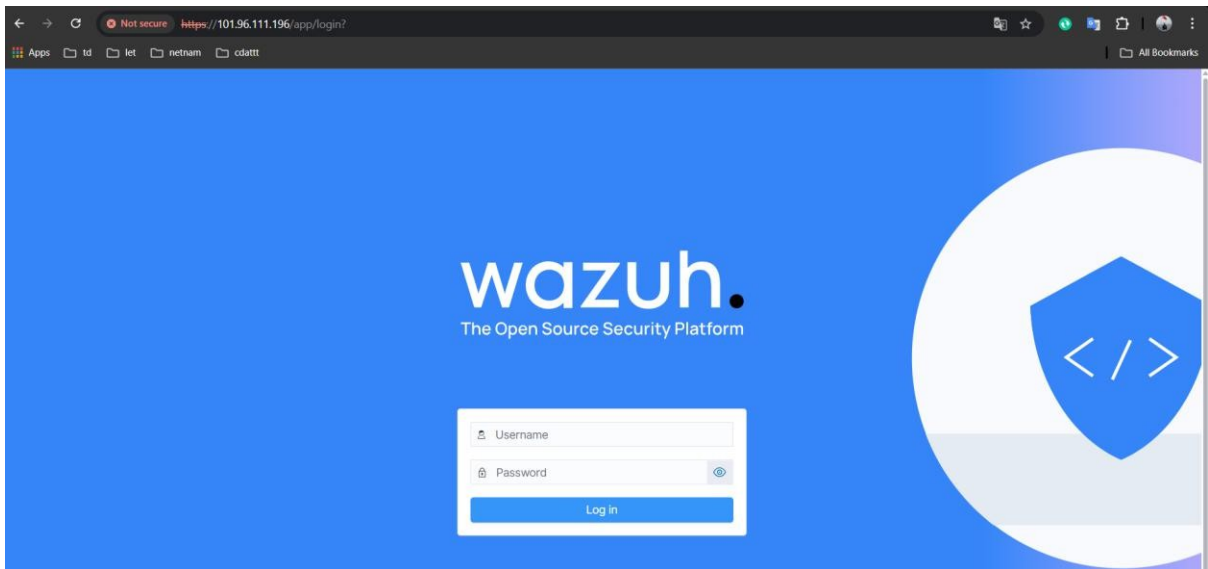
```
root@wazuh:/home/wazuh/wazuh-install-files# curl -k -u admin:XXXXXXXXXXXXXXXXXXXX https://101.96.111.196:9200
0
{
  "name" : "tqc-indexernode1",
  "cluster_name" : "wazuh-indexer-cluster",
  "cluster_uuid" : "uVPRfqv2RGu5qPLH8TCLOw",
  "version" : {
    "number" : "7.10.2",
    "build_type" : "deb",
    "build_hash" : "ac8f6e0114b657a116c4a41c3e12f8e0e181bbcd",
    "build_date" : "2025-11-08T12:00:46.843930578Z",
    "build_snapshot" : false,
    "lucene_version" : "9.12.2",
    "minimum_wire_compatibility_version" : "7.10.0",
    "minimum_index_compatibility_version" : "7.0.0"
  },
  "tagline" : "The OpenSearch Project: https://opensearch.org/"
}
root@wazuh:/home/wazuh/wazuh-install-files#
```

Sau khi cài xong wazuh-indexer, việc cài dashboad và manager chỉ cần chạy 2 lệnh là hoàn thành việc cài đặt SIEM Wazuh

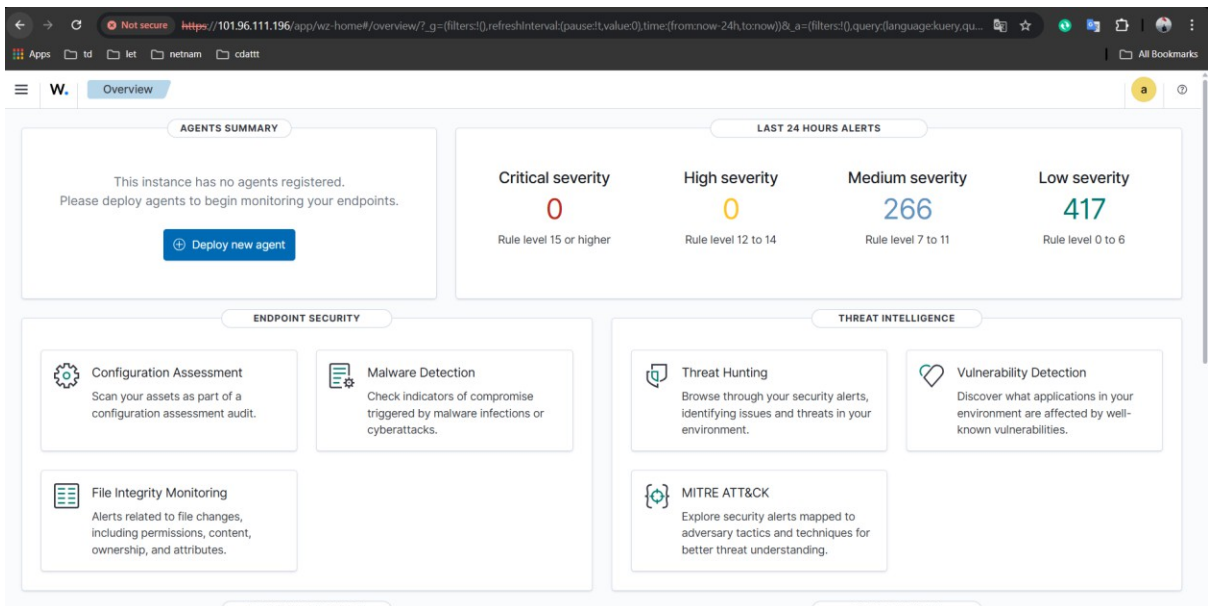
```
bash wazuh-install.sh --wazuh-server tqc-managernode1
```

```
bash wazuh-install.sh --wazuh-dashboard tqc-dashboardnode1
```

Bây giờ ta sẽ đăng nhập vào <https://101.96.111.196> của Server để kiểm tra xem dashboard đã lên chưa như ví dụ dưới là ta thành công cài được 3 thành phần indexer, dashboard, manager thông tin đăng nhập ta vẫn sẽ lấy ở trong file `wazuh-passwords.txt`:

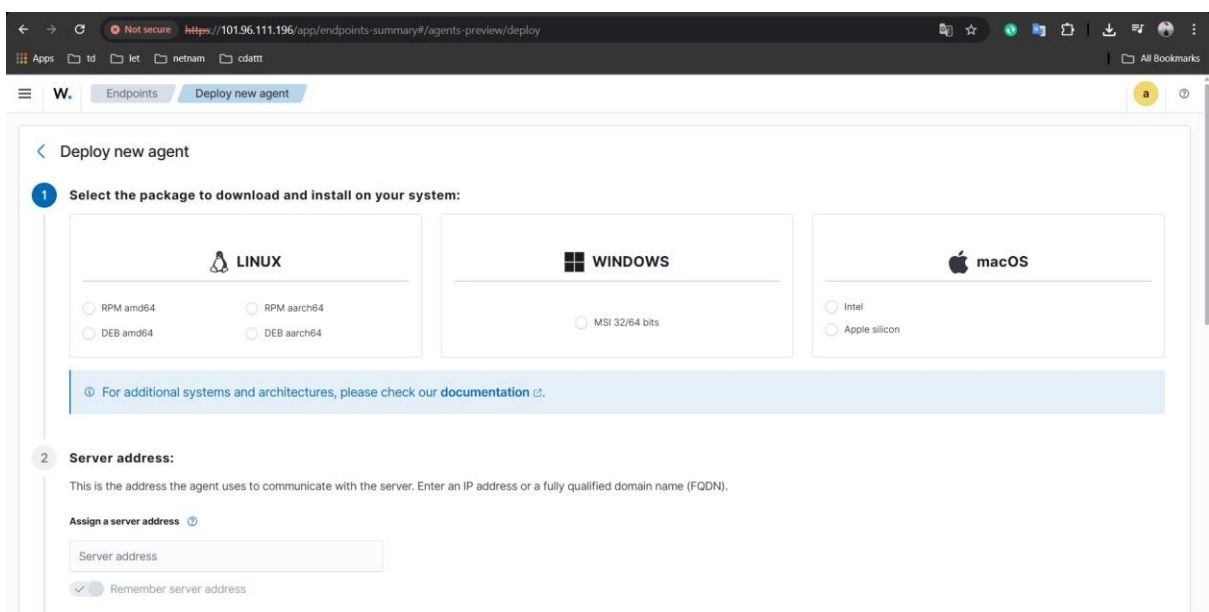


Đây chính là giao diện chính của SIEM Wazuh



B. CÀI ĐẶT AGENT LÊN WINDOWS VÀ UBUNTU

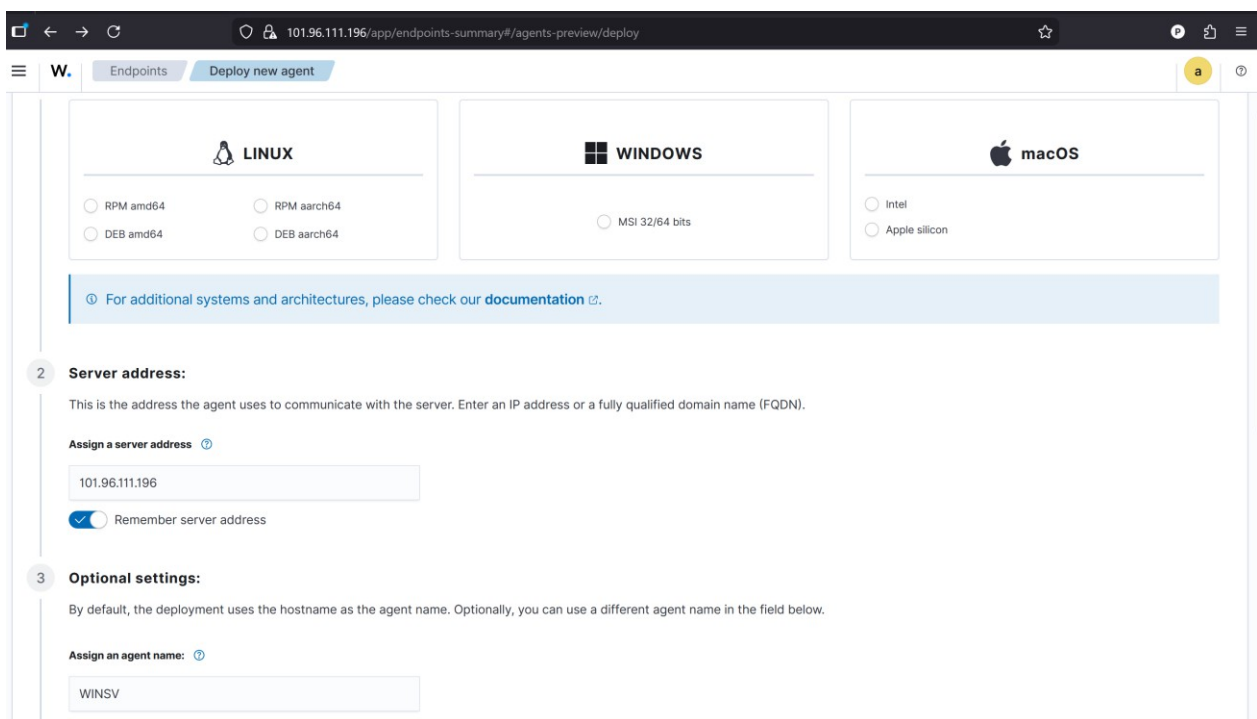
Để cài Agent hệ điều hành Windows/Ubuntu ta sẽ vào mục ở góc trái trên màn hình Dashboard và chọn mục Agent Management > Summary rồi chọn Deploy new agent ta sẽ được chuyển qua màn hình sau:



Tùy vào lại Agent mà ta muốn cài đặt trên máy đó nếu ta muốn cài trên máy Windows ta sẽ tích trong mục Windows còn nếu cài trong Linux ta sẽ chọn bên Linux

Ở phần Server Address ta sẽ điền IP của SIEM Wazuh còn Agent name ta sẽ đặt tên tùy ý.

Ở phần groups ta sẽ sử dụng luôn nhóm Default, có thể tham khảo mẫu thiết lập dưới hình sau:



Sau khi thiết lập các thông tin cơ bản trên ta sẽ được cấp cho 1 đoạn script cài đặt agent tùy thuộc vào hệ điều hành của máy đó

Đối với máy Windows:

Ta sẽ chạy 2 script này trên Powershell với quyền Admin:

```
PS C:\WINDOWS\system32> NET START Wazuh
```

```
PS C:\WINDOWS\system32> NET START Wazuh
```

Đối với máy Ubuntu:

```
root@ducq-virtual-machine:~# wget https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.14.1-1_amd64.deb && sudo WAZUH_MANAGER='101.96.111.196' WAZUH_AGENT_NAME='ducq-virtual-machine' dpkg -i ./wazuh-agent_4.14.1-1_amd64.deb
```

```
root@ducq-virtual-machine:~# sudo systemctl daemon-reload
root@ducq-virtual-machine:~# sudo systemctl enable wazuh-agent
root@ducq-virtual-machine:~# sudo systemctl start wazuh-agent
```

TÀI LIỆU THAM KHẢO

- [1] Wazuh Inc., Wazuh Documentation – Open Source Security Platform, <https://documentation.wazuh.com>
- [2] Shuffler.io, Shuffler Documentation – The Open Source SOAR for all purposes, <https://shuffler.io/docs>
- [3] Security Orchestration, Automation and Response (SOAR) Buyer's Guide An Ultimate Guide for SOAR - Logsign